A Hybrid Approach for Automated Security Pattern Recovery

Anh Minh Nguyen
University College Dublin
Dublin, Ireland

Tuan Dat Tran
University College Dublin
Dublin, Ireland
dat.tran@ucdconnect.ie

Alzubair Hassan
University College Dublin
Dublin, Ireland
alzubair.hassan@ucd.ie

Liliana Pasquale
University College Dublin
Dublin, Ireland
liliana.pasquale@ucd.ie

arXiv:2611.05823v1 [cs.CR] 4 Nov 2026

Abstract*—Security-by-design emphasises integrating security into software design and development. Security pattern catalogues operationalise this principle by prescribing reusable architectural solutions to recurring security problems. However, recovering their implementations from source code remains challenging because security patterns are abstract, span multiple components, and admit many valid implementations. We present SecPatRec, a hybrid approach for automated security pattern recovery from source code repositories. We treat a security pattern as a reference architecture and frame its recovery as a deductive task: determining which prescribed roles are present, grounding them in code entities, and recovering their interaction sequences. SecPatRec pairs a ReAct-style LLM agent equipped with semantic and lexical code search for role detection and grounding with static code property graph analysis for interaction recovery. We curate a human-validated ground-truth dataset of 100 pattern instances covering five security patterns across 93 open-source Java and Python repositories, and introduce a three-level evaluation framework measuring recovery correctness against this ground truth. We evaluate SecPatRec using four LLMs, including proprietary and open-source models. Averaged over all models and pattern instances, SecPatRec achieves role-detection accuracy of 0.84, role-grounding similarity of 0.84, and an interaction-recovery score of 0.66. Compared to a one-shot end-to-end LLM baseline, SecPatRec achieves higher aggregate recovery scores and lower estimated LLM API costs per run, while processing repositories that exceed the baseline's configured input limit. The recovered role mappings and statically derived interaction sequences provide structural and behavioural evidence that can support inspection of security-pattern implementations.

I. Introduction

Software vulnerabilities can arise from weaknesses in a system's design as well as from implementation mistakes. McGraw estimates that roughly half of software security defects are design flaws [1], not implementation bugs [2]. Security-by-design emphasises integrating security into software design and development [2], [3]. The EU Cyber Resilience Act reinforces this goal by establishing cybersecurity requirements for products with digital elements made available on the EU market [4]. Tracing architectural security decisions to their implementation supports inspection of whether the code reflects the intended design [5]. However, this inspection is difficult when developers have only a partial view of the security architecture [6], or when architectural documentation is missing, outdated or inconsistent with the code [7], [8].

Security patterns are one of the primary means of security-by-design: they document reusable architectural solutions to recurring security problems [9]–[11]. A pattern describes a solution through architectural *roles* and the *actions* between them, providing both a blueprint for implementing a security control and a reference for inspecting an existing implementation. Unlike the Gang of Four design patterns [12], which offer code-level guidelines, security patterns admit multiple valid implementations. A role may be realised through different classes, functions or library calls, depending on the language, framework and application context [11], [13], [14], and an implementation may span several components. Consequently, finding individual security mechanisms does not establish how the pattern is implemented. Recovering the roles and their interactions can support architectural inspection and enable larger-scale empirical studies of how security patterns are used in practice, for which evidence remains limited [15], [16].

In this paper, we address *automated security pattern recovery*: given a security pattern and a codebase, determine which prescribed roles are present, ground them in code entities, and recover their interaction sequence. Because a security pattern describes both structure and behaviour, we treat it as a *reference architecture* and frame recovery as a deductive software architecture recovery (DSAR) task [17]. The pattern specification guides the search for implementing entities, including code defined within the repository and references to externally defined functionality.

Three challenges motivate our approach. *First, roles are implemented in many ways.* Prior work detects security patterns by architectural analysis and pattern matching [18], [19]; Bunke and Sohr, for example, match connected object process graphs and evaluate on a benchmark of Android applications [20]. LLM-assisted DSAR adds a different ability: it finds code units by what they mean rather than by their structure [17], [21]. We ask whether this can detect and ground roles in Java and Python repositories too large for a single prompt. *Second, role mappings alone are not enough.* They say which entities play the roles, not how those entities interact, and LLM-assisted DSAR only supports the mapping [17], [21]. Static analysis can supply the call relationships and their order. *Third, each recovery output needs its own measure.* Although architecture-level similarity measures provide useful comparisons of recovered architectures [22], [23], evaluat-

ing individual patterns requires measurements linked to role presence, code grounding and interaction recovery. Assessing these outputs and comparing recovery configurations requires human-validated annotations at this granularity, which we construct.

In this paper, we propose SECPATREC, a hybrid approach that combines an LLM agent with static code property graph (CPG) analysis [24]. Guided by the pattern specification, the agent iteratively uses semantic and lexical code search to locate and inspect relevant code, producing role mappings and presence statuses. CPG traversal then uses these mappings to recover interactions between the identified entities. This division combines semantic interpretation of architectural roles with interaction evidence extracted from source code. To evaluate the approach, we construct human-validated ground truth and define three corresponding correctness metrics.

Our contributions are:

- SECPATREC, a hybrid approach to automated security pattern recovery, with specifications from the Van Den Berghe catalogue [11] as reference architectures.
- **A human-validated ground-truth dataset** of 100 security pattern instances covering five patterns across 93 open-source repositories: 49 Python and 44 Java projects. Each pattern is represented by ten instances per language. Each instance records role-to-code mappings, role presence statuses and an interaction sequence.
- **A three-level evaluation framework** that measures recovery correctness against the ground truth through role detection accuracy (RDA), mapping localization score (MLS) and interaction recovery correctness (IRC).
- **An empirical evaluation** using four LLMs, including proprietary and open-source models, across five patterns and two languages. We compare SECPATREC with a one-shot end-to-end LLM baseline, examine scalability with repository size, and assess how the code search tools affect correctness, token consumption and estimated LLM API costs.

Over the four models and all evaluated pattern instances, SECPATREC achieves a mean role detection accuracy of 0.84, a mean mapping localization score of 0.84 and a mean interaction recovery correctness of 0.66. It achieves higher aggregate recovery scores and lower mean estimated LLM API costs per run than the one-shot baseline, and processes repositories whose packed source exceeds the baseline's configured input limit.

II. SECURITY PATTERNS

Security patterns document reusable solutions to recurring security problems that occur in a particular security context [10], [25], [26]. We use the catalogue of Van Den Berghe et al. [11], published online by KU Leuven's DistriNet group[1], because it describes patterns through a common metamodel[2]. Each solution specifies the participating *roles*, the *actions* they perform, the *data elements* they exchange, and their *behaviour*. Roles represent entities or specialised entity types, such as enforcement points, decision points, storage and cryptographic primitives. Behaviour is described through a walkthrough and a diagram whose numbered interactions convey ordering information. The catalogue also provides coverage mappings to security-risk lists, including the OWASP Top 10 (2021).

Figure 1 presents an adapted view of the successful authentication flow of *Password-based authentication*[3]. The Subject sends an identifier and password to the Enforcer (b_1), which forwards them to the Verification manager (b_2). The Verification manager retrieves the stored password-verification value and its salt from the Password store (b_3), and requests a hash of the submitted password using that salt from the Hasher (b_4). In the peppered variant illustrated by the catalogue, it then retrieves the pepper (b_5), uses the Encrypter to encrypt the calculated hash with the pepper as the cryptographic key (b_6). The verification manager sends the resulting ciphertext and the stored password-verification value to the Comparator, which compares them with the stored value and returns the verification result (b_7). Following successful verification, the Enforcer forwards the request to the System (b_8), which may reply to the Subject (b_9). Intermediate replies and the failure branch are omitted from the figure.

For recovery, we retain the seven shaded roles and the interactions between them (b_2–b_7). Subject and System, together with b_1, b_8 and b_9, provide the surrounding context and are outside this recovery specification. Registration and password-reset behaviour described in the catalogue are also outside the selected flow. Details of flow selection are provided in Appendix A-A. Roles excluded when constructing the reference specification are outside scope; they are distinct from retained roles for which no implementation is identified.

The catalogue describes security responsibilities and interactions without prescribing a unique code structure. Roles do not always correspond to distinct classes, functions or modules, and a library operation may realise several roles. For example, Figure 2 maps the Enforcer, Verification manager and Password store to three functions in a simplified FastAPI login handler, and maps the Comparator to an externally defined `passlib` password-verification call. Additional responsibilities, such as password hashing, may be encapsulated by the same call. The handler contains no explicit peppering step. Recovering a role therefore requires interpreting the available code and library references in context [13], [14]. Section III formalises the recovery outputs and their presence statuses.

III. AUTOMATED SECURITY PATTERN RECOVERY

A. Problem Formulation

In this paper, our goal is to recover the architectural components of security patterns from existing codebases. The target catalogue is the Van den Berghe's developed by KU Leuven's Distrinet group [11]. We observe that security

[1]https://securitypatterns.distrinet-research.be/patterns/

[2]https://securitypatterns.distrinet-research.be/metamodel/

[3]https://securitypatterns.distrinet-research.be/patterns/01_01_002_authentication_pwd/

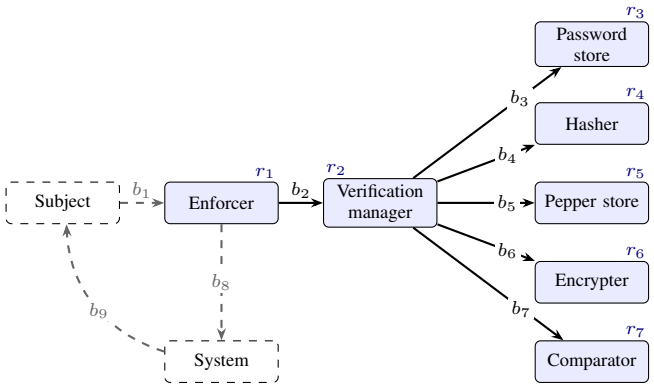


Fig. 1. The *Password-based authentication* pattern of the catalogue [11], reduced to its roles r_i (boxes) and the actions b_j between them (arrows), in the order of the pattern's walkthrough.

patterns in the Van den Berghe's catalogue express both the structural properties and the behavioral properties of a security architecture [27], [28]. As a result, mining a reference security pattern from a codebase can be approached as a deductive software architecture recovery (DSAR) problem [17], [21], focusing on the tasks of matching architectural roles that the pattern prescribes to specific classes or functions, and to derive the sequence of interactions between the matched roles. We formulate this problem as follow:

A security pattern, or pattern is specified as a tuple $P = (R, B)$, where:

- **Roles (R):** A vocabulary $R = \{r_1, \ldots, r_m\}$ of prescribed architectural entities. For example, a password-based authentication pattern might prescribe $R = \{\textit{Enforcer}, \textit{Verification manager}, \textit{Hasher}, \textit{Password store}\}$.
- **Actions (B):** An ordered sequence $B = \langle b_1, \ldots, b_n \rangle$ dictating the behavioral flow between those roles.

The pattern itselfs can serves as the reference architecture to be recovered against a codebase C. Recovering P from C requires three tasks: (1) detect which roles of P are present in C, by identifying the presence status of each role that composes the pattern, (2) map each prescribed role $r \in R$ to a concrete code symbol $e \in \mathcal{E}(C)$ where $\mathcal{E}(C)$ represents the union of all Abstract Syntax Trees (AST) nodes inside the codebase, and (3) recover the sequence of interactions between those mapped symbols. We denote the recovered architecture as a tuple $(M, \mathcal{D}, S)$, where:

1) **Role mappings (M):** A set of pairs $m = (r, e)$ with $r \in R$, each mapping a prescribed role to the code symbol e that implements it, where e is either defined in C, i.e., $e \in \mathcal{E}(C)$, or only referenced by C.
2) **Presence statuses ($\mathcal{D}$):** The set $\mathcal{D} = \{\delta(r) : r \in R\}$ of presence statuses, one for each role. $\delta(r) = \textsc{present}$ when there exists $m \in M$ that maps r to some $e \in \mathcal{E}(C)$. $\delta(r) = \textsc{external}$ when there exists $m \in M$ that maps r to some e whose definition cannot be found in any AST of C, such as a library function that C only calls. $\delta(r) = \textsc{missing}$ when there exists no $m \in M$ that maps r to any e.
3) **An interaction sequence (S):** The ordered sequence of actual interactions observed between the mapped symbols in M.

TABLE I
NOTATION.

Symbol	Meaning
Pattern specification	
$P = (R, B)$	pattern specification
R, B	prescribed roles; their actions, in order
Codebase	
C, $\mathcal{E}(C)$	codebase, and its named code symbols extracted from union of all ASTs
Recovered Architecture	
M, $\mathcal{D}$, S	ground truth: role mapping, presence statuses, interaction sequence

Table I summarizes this formulation. Figure 2 illustrates the recovery of the pattern from a small login handler that implement the password-based authentication pattern mentioned in Figure 1. The quality of an automated security pattern recovery solution depends on how correctly it can produce the mentioned above outputs. To evaluate these level of correctness, we need to not only define the corresponding set of metrics that align with outputs of the recovery, but also a cureated groundtruth sets of the role mapping M, the presence statuses $\mathcal{D}$ and the interaction sequence S that are collected from the original software architecture. This is a chalenging task, as groundtruth architectures in real-world open-source software are scarce, requiring involvement of human expertise to generate them [22], [29].

B. SecPatRec: Automated Approach for Deductive Security Pattern Recovery

Our goal is to design an automated approach that can recover the architectural components of security patterns from existing codebases, including the role mapping M, the presence statuses $\mathcal{D}$ and the interaction sequence S, using the pattern specification P as the reference architecture for DSAR. Previous works in DSAR have shown that LLMs can be used for code unit classification effectively [17], [21], which is suitable for the task of generating candidate role mappings $\hat{M}$, and consequently the presence statuses $\hat{\mathcal{D}}$ of the roles. However, for large real-world codebases, chunking all code symbols in $\mathcal{E}(C)$ to feed into LLMs for batched classification tasks could be computationally expensive and time-consuming [31], and at the same time losing repository-level global contexts as code symbols have been fragmented and processed individually [32]. Also, individual code unit classification can not be adopted for the next task of security pattern recovery, which is recovering a sequence of behaviorial interactions between the mapped roles.

To address the above challenges, we propose a hybrid approach that combines LLMs with code search methods and static code property graph (CPG) analysis [24] to recover the

```python
from fastapi import Depends, FastAPI
from passlib.context import CryptContext
app = FastAPI()
pwd = CryptContext(schemes=["bcrypt"])

def get_user(db, name):
    return db.get(name)                          δ(r3) = PRESENT

def authenticate(db, name, password):
    user = get_user(db, name)
    if user and pwd.verify(password, user.hash):
        return user                              δ(r7) = EXTERNAL
    return None                                  δ(r2) = PRESENT

@app.post("/login")
def login(form: LoginForm, db=Depends(get_db)):
    user = authenticate(db, form.name, form.password)
    return user                                  δ(r1) = PRESENT
```

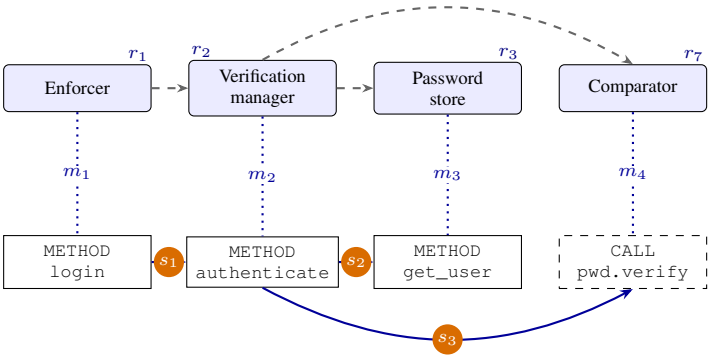


Fig. 2. A login handler (left) and the architecture recovered from it for the password-based authentication pattern (right): roles r_i, role mapping m_i (dotted), pattern actions (dashed) and interaction sequence s_j (solid). Boxes in the code give $\delta(r_i)$, dashed for EXTERNAL. The handler is simplified from the FastAPI documentation [30].

architectural components of Van De Berg's security patterns from existing codebases. LLM that used chain-of-thought reasoning with code search as external tools is suitable for the tasks of security pattern roles' detection and mapping, which requires iterative localization of relevant code contexts from a large source global semantic information [32], [33], while CPG analysis provides a deterministic way to bridge the mapped roles and their interactions. The overall design of our approach is illustrated in Figure 3.

1) Security Pattern Role Mapping and Presence Detection: **Translate Pattern Specification into Architecture Description Language Code** The pattern specification P from the Van De Berg [11],is documented as textual descriptions in Markdown format and PNG images of their corresponding UML diagrams. We want to translate these information into a reference architecture description language (ADL) code to guide the LLM chain-of-thought reasoning in the role mapping and presence detection tasks. This translation is done by our developed ADL code generator, which provides Mermaid and JSON code representation of the prescribed roles and their interactions. Details on how we implement this translation are provided in Appendix A-A. The generated ADL code is then used to construct a prompt for the LLM to perform the role mapping and presence detection tasks.

Iterative Tool-assisted CoT Role Detection and Mapping We perform role detection and mapping with ReAct [34], an iterative reasoning method that lets an LLM interleave chain-of-thought with calls to external tools. At each iteration, the LLM first writes a *Thought* about what it has learned so far from a codebase and what to look for next, then issues one *Action*, i.e., a call to external code search tools, or trigger particular file reads and finally reads the *Observation*, a code context returned by that specific tool call. The iterations continue until the LLM has detected and mapped every role of P. The system prompts for this process is inserted with the previously translated JSON ADL code to guide the reasoning.

The LLM explores the codebase C through two search methods. *Semantic search* takes a description in natural language and returns a code symbols in C. We vectorize every symbol with BGE-small [35][4], and then store them in ChromaDB for later retrieval triggers. *Lexical search*, instead, finds a literal string or a regular expression anywhere in the repository and returns the matching lines with their file and line number. The combination of 2 search methods allows the LLM to both semantically and syntatically locate and analyze relevant code elements [33], [36]. The LLM can also list directories and read files to inspect what code searches return.The final output of this task is a structural set of role mappings $\hat{M}$ and theoir presence statuses $\hat{\mathcal{D}}$, which are passed on to the next task of recovering the interactions. Outputs of this stage are JSON files that contain the role mapping $\hat{M}$ and the presence statuses $\hat{\mathcal{D}}$ of the roles, formatted as in Figure 18a in Appendix B.

2) Interaction Sequence Recovery: **Constructing the Code Property Graph** Once the role mapping $\hat{M}$ and presence statuses $\hat{\mathcal{D}}$ are obtained, we construct the CPG of the targeted codebase C using Joern[5], a Scala-based platform that can model source code for security-relevant tasks [24]. The CPG captures the structural and behavioral relationships between code symbols, allowing us to analyze the interactions between the mapped roles.

Traverse the CPG to Recover Interactions between Mapped Roles We define our own traversal rules to derive the calling relationships between the mapped code symbol entities $\hat{e}$ corresponding to every $\hat{m}$ in $\hat{M}$, and recover the interaction sequence $\hat{S}$ (Figure 18b) based on the order of the calls observed in the CPG. Details of how we construct the traversal rules are provided in the Appendix C, and the Scala implementation is available in our repository[6].

IV. Experiment Setup

A. Research Questions

To evaluate our automated security pattern recovery approach, we want to understand how well it performs in terms

[4]Checkpoint `BAAI/bge-small-en-v1.5`, https://huggingface.co/BAAI/bge-small-en-v1.5.

[5]https://joern.io

[6]https://github.com/anonymousspottedtoad/secpat_interaction_recovery

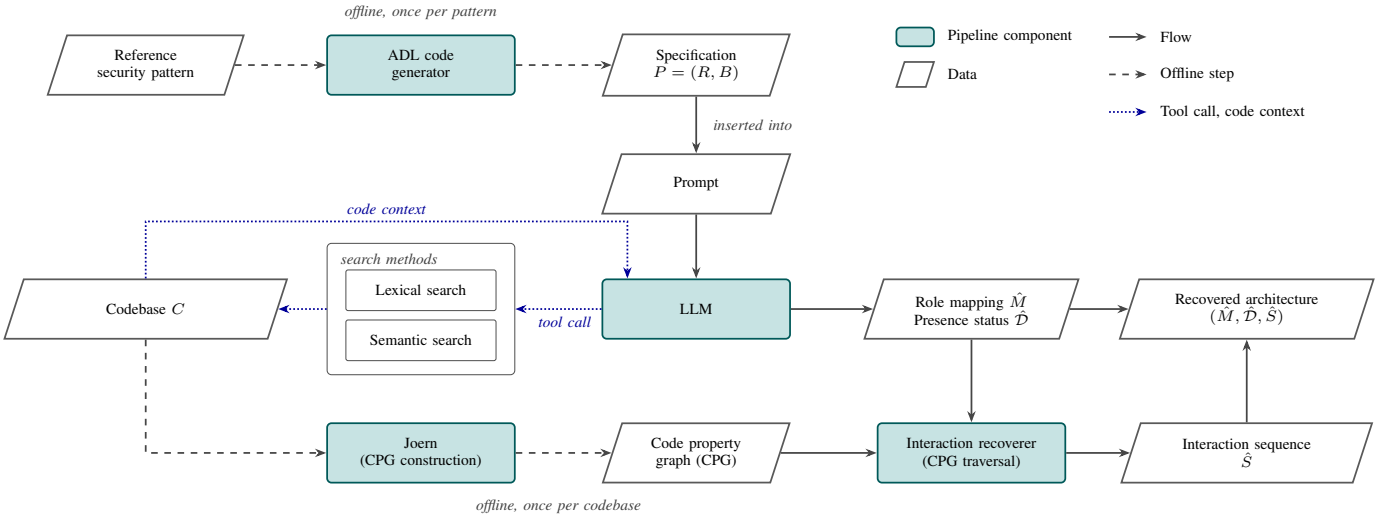


Fig. 3. Overview of SECPATREC. The specification P is inserted into the prompt of the LLM, which iteratively searches the codebase C and produces the role mapping $\hat{M}$ and the presence statuses $\hat{\mathcal{D}}$. The CPG of C is built offline with Joern, and the interaction recoverer traverses it from the mapped symbols to produce the interaction sequence $\hat{S}$.

of recovery correctness, costs of computing resources and token consumption, under different LLMs and code search methods. We also want to valide our assumption that using CPG analysis is more efficient and scalable compared to an end-to-end baseline that use LLM only. We define following research questions (RQs) to guide our evaluation:

> **RQ$_1$.** *Which LLMs has the best **task-specific performance** for security pattern recovery?*

> **RQ$_2$.** *Which LLMs is the most **cost-effective** for security pattern recovery tasks when integrated with CPG analysis in our pipeline, in terms of **token consumption**?*

> **RQ$_3$.** *How does each **LLM**, when integrated with CPG analysis in our pipeline, can scale across **diffrent patterns** and **codebase sizes**, compared to their **end-to-end LLM baseline** counterparts, in terms of performance and computing resource usage?*

> **RQ$_4$.** *How do **code search methods** affect the quality of the recovered architecture and the overall computing cost of running security pattern recovery tasks?*

To answer the above questions, we had to first establish a groundtruth dataset of security pattern architectures M, D, S, and at the same time define performance indicators to measure the correctness of our approach in terms of task-specific metrics for security pattern recovery. The details of the groundtruth dataset and the evaluation metrics are described below

B. Groundtruth Dataset of Security Pattern Architectures

1) Choosing Patterns for Reference and Codebases for Recovery: The pattern-problem pairs in Van De Berg's catalogue are developed with the aims to cover OWASP Top 10 security risks in web application [7]. As a result, we want to use real-world open-source codebase that implements security control for web applications for validation our approach. We use our custom tool [8] to automate the cloning of 93 repositories from Github. The choice of repositories is based on the condition that they depend on 2 corresponding web security frameworks: Python's FastAPI and Java's Springboot Security. The selection of FastAPI and Spring Boot was driven by their widespread adoption; as of 2025, they are used by 38% and 65% of their respective developer communities [37], [38]. The target patterns used as reference architectures are P1 Password-based authentication, P2 Verifiable-token authentication, P3 Obscure-token access control, P4 Session-based access control and P5 Rate limiting. They all belong the set of security solutions that tackle the security problems related to OWASP's Top 10 2025: A01: Broken Access Control and A07: Authentication Failures [39].

Details statistics of the selected codebases and the corresponding security patterns are provided in Table II and Figure 34 in Appendix D-D, where code size is measured in KLOC and in tokens of OpenAI's `o200k_base` tokenizer[9]. Our source of target codebases for recovery spans 49 repositories in Python and 44 repositories in Java. We preprocess these repositories to collect only .java and .py sources files with a total of 272,137 methods and 54,785 classes extracted from their ASTs. We also construct the CPGs of these codebases using Joern, consuming a total of 818.5 MB of storage space. Our repositories are diverse in terms of their size, making it suitable for evaluating the scalability and performance of our approach.

[7] https://securitypatterns.distrinet-research.be/coverage/
[8] https://github.com/username/repo
[9] https://github.com/openai/tiktoken

TABLE II
SIZE OF THE 93 CODEBASES PER LANGUAGE.

	#Repos	KLOC	#Methods	#Classes	#Tokens	#Files	CPG (MB)
Java	44	3,628.2	179,975	37,478	32.12M	32,628	228.3
Python	49	2,555.4	92,162	17,307	20.89M	10,622	590.2
Total	93	6,183.6	272,137	54,785	53.01M	43,250	818.5

2) Constructing Groundtruths: Obtaining groundtruth for software architecture recovery is inherently difficult, as knowledge of the system architects who designed the architecture is rarely available [22], [29]. As a result, previous works [22], [23], [29] had to rely on *authorative protocol*, in which an automated process is used to generate a set of *preliminary architectures*, and then external human engineers are used to certify them. In this work, we follow a similar approach, but instead use Claude Code to generate a the preliminary role mappings M and presence statuses $\mathcal{D}$, then have human experts verify them. This human-AI collaboration annotation approach is also used in previous software engineering and mining software repositories works [40], [41]. We share our working session of how we use Claude Code to generate preliminary mappings in Appendix D. We then traverse the CPGs to deterministically recover the preliminary interaction sequence S among provided preliminary M, using the same traversal rule as mentioned in III-B2.

To help human annotators verify the preliminary architectures, we provide them with a web-based interface that allows them to inspect the preliminary role mappings and presence statuses, visualizing the candidate interaction sequence recovered, allowing annotators to trace the interactions between the mapped roles and code entities. Annotators are provided with the original Van de Berg's catalogue for reference. They can approve or reject, or modify each preliminary roles mapping and interaction themselves if they think that existing recovery do not reflect the design that the orginal pattern intended. They can also map a single codebase with more than one security patterns, as in real-world open-source projects, developers can apply multiple security solutions to a single codebase [14]. We have two annotators, both of whom are senior software engineers that has more than 4 years of web application development. Example of how we visualize the candidate groundtruths for human verification is provided in Appendix D.

After the annotators have finished their verification, we sampled a list of 100 groundtruth architectures, each of which contains a human-verified role-to-code mappings M, role presence statuses $\mathcal{D}$ and an interaction sequence S between the mapped roles. In total, the 100 groundtruth architectures contain 500 roles, of which 334 are present, 75 external and 91 missing, and 280 interactions; Table III gives them per pattern and language. We publish the dataset in an anonymized Hugging Face bucket for reuse and reproducibility[10].

[10]https://huggingface.co/buckets/AnonymousSpottedToad/securityPatternsRecovery

TABLE III
GROUNDTRUTH ROLES BY PRESENCE STATUS AND INTERACTIONS PER PATTERN, FOR PYTHON AND JAVA (10 CODEBASES EACH).

	Python				Java			
Pattern	Pres.	Ext.	Miss.	Int.	Pres.	Ext.	Miss.	Int.
P1	32	17	21	31	33	14	23	39
P2	31	9	0	24	28	12	0	27
P3	33	0	7	19	30	6	4	28
P4	42	0	18	19	31	11	18	25
P5	40	0	0	34	34	6	0	34
Total	178	26	46	127	156	49	45	153

C. Evaluation Metrics

For each task of security pattern recovery, we define task-specific performance indicator to measure the correctness of our approach. We define one metric for each output of the recovery, comparing the presence statuses $\hat{\mathcal{D}}$ with $\mathcal{D}$, the role mapping $\hat{M}$ with M, and the interaction sequence $\hat{S}$ with S. We call them role detection accuracy (**RDA**), mapping localization score (**MLS**) and interaction recovery correctness (**IRC**). A metric is computed for one recovery instance, i.e., one pattern recovered from one codebase, and is then averaged over all instances. The implmentation of our evaluation metrics is available in our repository[11]. Appendix A-D shows the three metrics on a small example (Figures 16 and 17).

1) Role Detection Accuracy: Each role of the pattern has one of three statuses: PRESENT, EXTERNAL or MISSING. Role detection accuracy is the fraction of roles for which the LLM outputs the same presence status $\delta(r)$ compared to the groundtruth $\delta(r)$, so the problem is translated into a multi-label classification problem over the closed label set R

$$\mathrm{RDA} = \frac{\left|\{\, r \in R : \hat{\delta}(r) = \delta(r) \,\}\right|}{|R|}. \tag{1}$$

2) Mapping Localization Score: For every role founded by the both the LLM and the groundtruth, i.e $r \in F$ where $F = \{\, r \in R : \delta(r) \neq \text{MISSING} \text{ and } \hat{\delta}(r) \neq \text{MISSING} \,\}$, we want to measure how close the recovered symbol $\hat{e}_r$ that the LLM maps to r, compared with the groundtruth symbol e_r. We therefore measure how far apart the two symbols are in the static containment tree $T_(C)$ of the codebase, in the same way as fault localization is judged by the distance between the reported and the actual faulty location in the program dependence graph [42]: the closer the two symbols, the better the mapping localizes the role in the code. $T_(C)$ is constructed by agrregating all ASTs of source files in the codebase. The distance d is the number of edges required for moving e_r to $\hat{e}_r$ in the same $T_{(C)}$.

$$\begin{aligned} d(\hat{e}_r, e_r) = \mathrm{depth}(\hat{e}_r) + \mathrm{depth}(e_r) \\ - 2\,\mathrm{depth}\big(\mathrm{LCA}(\hat{e}_r, e_r)\big). \end{aligned} \tag{2}$$

[11]https://github.com/anonymousspottedtoad/secpat_evaluation_metrics

where LCA is the lowest common ancestor of the two symbols in the containment tree. We normalize this distance by the height $2H$ of the containment tree as no path in a tree of height H is longer than $2H$ edges, then score the tree-induced similarity as $1 - d/2H$. The mapping localization score is the mean score over all roles in F, and it is 0 when no role is found by both sides ($|F| = 0$), as then nothing is mapped correctly:

$$\text{MLS} = \begin{cases} \frac{1}{|F|} \sum_{r \in F} \left(1 - \frac{d(\hat{e}_r, e_r)}{2H}\right) & |F| > 0, \\ 0 & |F| = 0. \end{cases} \tag{3}$$

This approach to measure structural similarity between two security-relevant code entities using tree-induced similarity has also been used previously in vulnerability detection and root cause analysis literatures [42]

3) Interaction Recovery Correctness: Given two interaction sequences, the groundtruth S and $\hat{S}$ recovered from our CPG analysis methods. We want to measure how close $\hat{S}$ is to S, in terms of both the interaction b found in both sequential similairty and the order they are performed.

During the CPG analysis, there could exist unexpected recovered interactions outside S between any two roles, caused by the mismatch in previous mapping task, or there exist concrete call element between those two roles, but are not in the groundtruth sequences. Let $k = |S \cap \hat{S}|$ be the number of interactions shared by the groundtruth. We calculate the Jaccard index $J = k/|S \cup \hat{S}|$ to measure sequential similarity. We also interest in assessing if the order of the groundtruth interactions is preserved. For every k shared interactions between S and $\hat{S}$, they form $\frac{1}{2}k(k-1)$ interaction pairs (Figure 17). Let c be the number of interaction pairs that S and $\hat{S}$ put in the same order (concordant), and q the number of pairs they put in opposite orders (discordant). We calculate the unsigned Kendall's tau $\tau = c/\frac{1}{2}k(k-1)$ to measure this agreement in the ordering of the shared interactions. We then multiply τ with J to calculate the final sequential correctness score IRC between the groundtruth and recovered interaction sequences. The final score is defined as follows:

$$\text{IRC} = \begin{cases} \frac{c}{\frac{1}{2}k(k-1)} \cdot \frac{k}{|S \cup \hat{S}|} & k > 1, \\ \frac{k}{|S \cup \hat{S}|} & k \leq 1. \end{cases} \tag{4}$$

When $k \leq 1$ there is no pair to put in the wrong order, so τ is 1 and IRC is J alone, which is 0 when $k = 0$.

D. Model Selection

We choose our set of LLMs to evaluate on based on their benchmarked performace in full-stack web development tasks, since we want to make sure that they have been exposed to modern web security libraries that the groundtruth dataset is built on. Based on the top 20 results from CodeArena's WebDev benchmark[12], we select the following 4 LLMs for evaluation: OpenAI's GPT 6.1 Sol, Meta's Muse Spark, Deepseek-v4.0-Flash-0731, and GLM-5.3. GPT and Muse are propietary LLMs, so we use their API endpoints to call them. Deepseek and GLM are open-source LLMs, so we host them on our cloud server with 2x NVIDIA's B200 GPUs and 3x B300 GPUs on ModalAI's infrastructure. We use the same prompt template for all LLMs, and the maximum tokens that all 4 LLMs can process are set to 1,000,000 tokens. Each LLM is run once per instance and setting, with a temperature of 0.7.

[12]https://arena.ai/leaderboard/code/webdev

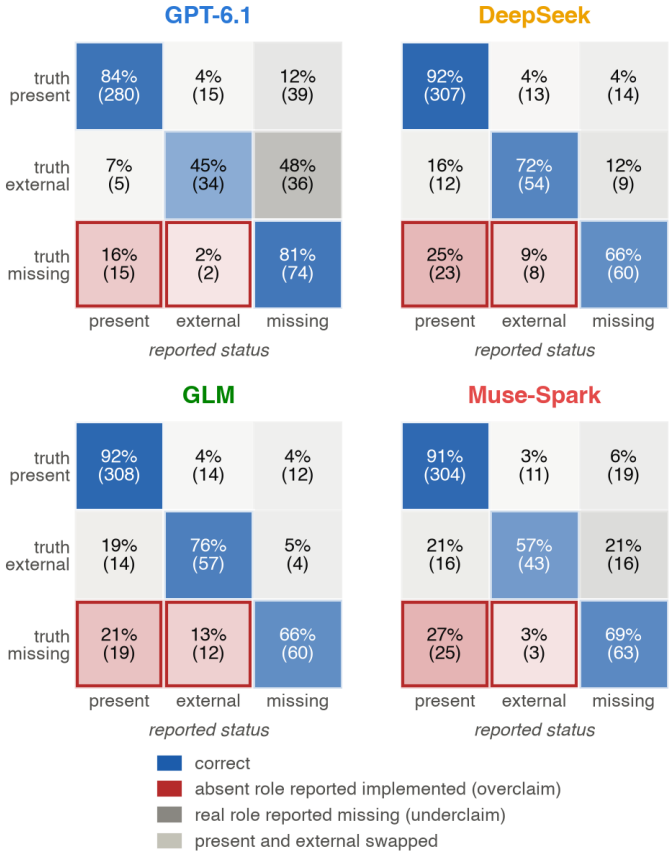


Fig. 4. Presence status reported by each LLM against the groundtruth, over the roles of the 100 instances (share of the row, count in brackets). Red frames: a missing role reported as present or external.

V. Evaluation

A. RQ1: Task-specific Performance

To answer this question, we ran our constructed pipeline on the dataset we built in Section IV-B. We evaluated the performance of each LLM on the three tasks mentioned in Section IV-C using their corresponding metrics RDA, MLS and IRC, and find out which LLM performs best on each task. Our overall evaluation results are shown in Figure 35 in Appendix E.

Overall, we find that the LLMs perform well on the task of pattern role's presence detection, with an average RDA (over the 100 instances) between 0.79 and 0.86. GLM and DeepSeek are the best performing LLMs on this task, both with an average RDA score of 0.86, while GPT-6.1 has the

lowest one (0.79). Looking at the confustion matrix in 4, we find that GPT-6.1, compared to other LLMs, is more likely to flag a role as missing when it is actually present, or called from an external library. This could be due to the fact that GPT-6.1 is more conservative in its predictions, and prefers to caution when it is not sure about the presence of a security-related component, or when it lacks the knowledge of a specific security library usage that is used in the codebase.

For the task of pattern role's mapping, the LLMs are close to each other, with an average MLS between 0.83 and 0.86. DeepSeek performs the best (0.86), followed by GLM (0.84), Muse-Spark (0.83) and GPT-6.1 (0.83). However, looking specifically at the mappings, we find that GPT-6.1 has more cases when it can perfectly ground the correct code entity. (See Table VIII in Appendix E).

For the task of interaction sequence recovery, we find that GPT 6.1 is the best performing LLM, with an average IRC score of 0.72. It is the best in Java's Springboot case (0.66, against 0.52 to 0.63 for the others), and on par with GLM in Python (0.78 for both). However, we find that all LLMs have a lower performance on this task (average IRC between 0.61 and 0.72) compared to the other two tasks.

> **Answer to RQ$_1$.** GPT-6.1 recovers interactions best (IRC 0.72, against 0.61 to 0.66), and its lead is largest on Java. GLM and DeepSeek detect roles best (RDA 0.86), while GPT-6.1 detects the fewest (0.79) because it is cautious and rarely claims a role that is absent. All four LLMs map roles about equally well (MLS 0.83 to 0.86), but GPT-6.1 maps the most instances exactly (27 of 100).

B. RQ2: Cost and Efficiency

We want to evalutate how many tokens are required for the tasks of pattern role's detection and mappings, with respect to each LLMs. As we are relying on iterative loop of LLM's CoT reasoning to perform the tasks, we want to see how many tokens are required for each iteration, and how many iterations are required for each task. Looking at the results in Figure 36 (Appendix E), we find that GPT-6.1 produces the fewest output tokens (1.4k to 1.8k per run), but its higher price makes it the most expensive LLM per run ($0.04 to $0.05). GLM uses the fewest new input tokens and is the cheapest, at about $0.005 per run.

It is also noted that the fees calculated for Deepseek-v4.0-Flash-0731 and GLM are esitimated based on their published pricing information [13] and [14], but in our experiments, we were hosting them on custom cloud server, and the actual cost of running them is not reflected in the pricing information.

[13]https://www.deepseek.ai/pricing
[14]https://www.glm.ai/pricing

> **Answer to RQ$_2$.** GLM is the most cost-effective LLM: it uses the fewest new input tokens and costs about $0.005 per run. GPT-6.1 produces the least output (1.4k to 1.8k tokens) but has the highest price per run ($0.04 to $0.05). DeepSeek and Muse-Spark produce 4 to 5 times as much output, and Muse-Spark also caches the least.

C. RQ3: Scalability across Codebase Size and Patterns Complexity

For each LLMs, we set up a series of baseline run with a diffrent prompt template (see Appendix A-C) to force them outputting $\hat{S}$ and $\hat{R}$ in one-shot, without the iterative loop of CoT reasoning, code search tools, or CPG analysis. We then compare the performance of each LLMs on the three tasks with respect to their baseline run counterparts, and find out how the SecPatRec pipeline and baseline differences scale across the five target patterns, and how they can retain their performance when the codebase size increases.

Looking at Figure 37 in Appendix E, we find that SecPatRec outperforms the baseline run in most patterns, partly because the baseline cannot run on the 16 codebases over its input limit, which score 0. On the 84 codebases both can run, the baseline is ahead in 21 of the 60 cases (five patterns, four LLMs and three metrics), mostly on RDA (9 cases), while our pipeline still has a higher overall IRC for every LLM (Table IX in Appendix E). However, we find that all models perform the worst in P4 Session-based access control, where their IRC (0.37 to 0.58) is the lowest among all five patterns, and is even lower in the case of Java (0.16 to 0.46). This is due to the fact that in Springboot, the Authorization Enforcer is not called by the Authentication Enforcer in the codebase: it is declared as an annotation (e.g., `@PreAuthorize`), and the Spring framework applies it at run time, after the Authentication Enforcer passes the request on (see Appendix F-A). As no call in the source code links the two enforcers, the CPG analysis cannot find the interactions between them, which leads to a low IRC score. That's why in P4 in Java, the baseline recovers the interactions better than our solution for most LLMs (three of four, e.g., 0.35 against 0.16 for GLM), as the baseline LLMs hallucinate the interaction order themselves, while SecPatRec can only recover the interactions existing inside the static CPG.

Figures 38 and 39 in Appendix E show the token cost side of scalability. The one-shot baseline has to read the whole codebase, so its token cost grows almost in proportion to the codebase size, where a ten times larger codebase costs 7 to 10 times more tokens, compared to only 1.2 to 1.9 times in SecPatRec, because the LLM only need to reads what the code search tools returns. The SecPatRec pipeline is therefore cheaper than the baseline for every codebase above 9k to 36k tokens, depending on the LLM, and at 1M tokens it is 6 (Muse-Spark) to 60 (GPT-6.1) times cheaper.

Figure 5 shows how recovery correctness changes with respect to codebase size. The RDA and MLS of SecPatRec do not decrease as codebases grow, while those number for the baseline drops dramatically, due to the size of 16 codebase exceeding the LLM's token limit. For interaction recovery

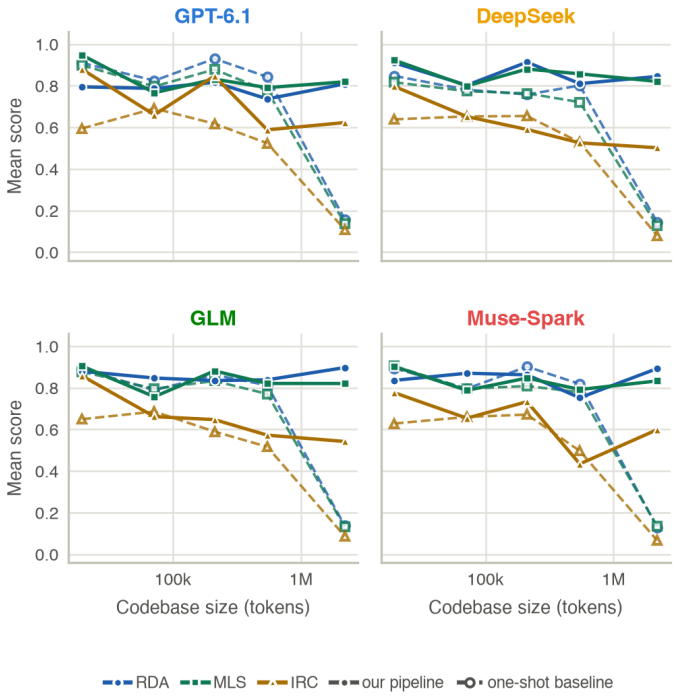


Fig. 5. Mean RDA, MLS and IRC against codebase size per LLM: SecPatRec (solid) against the one-shot baseline (dashed), in five size bins of about 20 instances. Instances over the baseline's input limit score 0 for the baseline.

task, looking at Figure 40 in Appendix E, when every role is mapped to exactly the right symbol from previous steps (MLS $= 1$, 80 instances), the CPG analyzer in SecPatRec recovers the interaction sequence perfectly (IRC $= 1$) on 73 of them, 0.93 on average, against 12% to 38% perfect instances in every lower MLS band. The CPG static analysis therefore scales with the codebase size.

Answer to RQ$_3$. The SecPatRec pipeline runs on the 16 of 100 codebases over the baseline's input limit, and on the 84 codebases both can run, it still has a higher IRC than the one-shot baseline for every LLM (+0.02 to +0.12) and a similar or higher MLS (-0.01 to $+0.10$; Table IX). SecPatRec cost barely grows with codebase size (log-log slope 0.08 to 0.28, against 0.83 to 1.00 for the baseline), so it is cheaper above 9k to 36k tokens and 6 to 60 times cheaper at 1M tokens, while RDA and MLS do not drop as codebases grow.

D. RQ4: Effects of Code Search Methods

Table X in Appendix E shows how the recovery changes when one search tool is removed from the LLM-based mapping stage. Removing either tool changes RDA and MLS by less than 0.03 for every LLM. To understand why, we counted the tool calls in every run. With both tools available, DeepSeek, GLM and Muse-Spark use keyword search for 80 to 93% of their searches, while GPT-6.1 uses the two about equally (46 to 52%). When one tool is removed, its calls move almost one for one to the other tool, and the number of steps per run changes by about one at most. The ReAct loop thus treats keyword and semantic search as interchangeable ways to find candidate code entities, which is why removing either of them, even the one an LLM prefers, does not hurt the recovery.

Answer to RQ$_4$. The ReAct uses keyword and semantic search interchangeably: when one is removed, its calls move to the other, and the run takes about as many steps. Removing either tool therefore changes RDA and MLS by less than 0.03, and changes IRC by -0.04 to $+0.09$ depending on the LLM. Removing semantic search saves 165 to 188 MB of memory without losing accuracy, so keyword search alone is enough when resources are limited.

VI. Discussion and Threats to Validity

A. Discussion

a) Why a hybrid design works: The RDA and MLS of SecPatRec stay flat as codebases grow (Figure 5), and when the roles are mapped exactly, the CPG traversal recovers the interaction sequence perfectly in 73 of 80 instances. Most of the IRC error therefore comes from the mapping stage, not from the traversal. This is the main argument for our hybrid design: the LLM handles the part of the task that needs an understanding of the code, while the static analysis reads the interactions from the code itself, without degrading as codebases grow. It also means that improving role mapping is the key to improving our approach.

b) What the static analysis cannot see: The CPG only contains the calls written in the source code, so it cannot see the interactions that only appear at run time, such as Spring's `@PreAuthorize`, Spring's bean injection, or FastAPI's `Depends`. This is why the one-shot baseline has a higher IRC than SecPatRec on P4 in Java. However, the baseline cannot observe this order in the code either, as it invents the order from its knowledge of Spring, so its higher IRC is not a better recovery. We leave reading the framework's configuration and annotations as future work.

c) Which LLM to use: We recommend GLM for low-cost recovery, as it costs about \$0.005 per run and matches the other LLMs on RDA (0.86) and MLS (0.84). GPT-6.1 is the best choice when the interaction sequence or exact mappings matter, with the highest IRC (0.72) and the most exact mappings (27 of 100), but at about 8 to 10 times the cost of GLM. It is also the most conservative LLM: it reports 48% of the external roles as missing, but it overclaims the least, reporting only 18% of the missing roles as present or external, against 30% to 34% for the others.

d) Extensibility to Future Security Pattern mining works: Our groundtruth dataset and evaluation metrics can serve as a benchmark for future security pattern recovery approaches, we publish our dataset at a customize and anonymized Huggingface bucket for public use and recreatibility[15]. The cost of SecPatRec barely grows with codebase size (log-log slope 0.08

[15]https://huggingface.co/buckets/AnonymousSpottedToad/securityPatternsRecovery

to 0.28, against 0.83 to 1.00 for the baseline). Since keyword search alone is enough (RQ4), the vector database and the embedding model can also be dropped. As a result, SecPatRec, a ReACt loop of LLM combining with lexical keyword search and CPG analysis can serve as an instrument to mine how security patterns are implemented at scale.

B. Threats to Validity

a) Construct validity: The specification P is itself generated by an LLM from the catalogue page and its main flow only, so an error in P would affect both the groundtruth and the recovery; to reduce this threat, we checked the five specifications by hand against their catalogue pages. Finally, scoring the 16 instances over the baseline's input limit as 0 mixes the instances the baseline cannot run with those it runs worse, so we also report the 84 instances it can run, where SecPatRec still has a higher IRC for every LLM (Table IX).

b) Internal validity: Each LLM was run once per instance and setting, so part of the differences we report may come from run-to-run variability, as the two ablation settings in RQ4 differ from each other as much as from the full pipeline. The ADL generator uses GPT-6 Sol, from the same vendor as GPT-6.1, but its prompts are fixed and its output P is the same for every LLM. Lastly, the 93 repositories and the catalogue are public, so the LLMs may have seen both during training.

c) External validity: Our evaluation covers two languages, two frameworks (FastAPI and Spring Security), and five authentication and access control patterns (A01 and A07) from one catalogue, on repositories selected by their dependency on these frameworks. Within this scope, the Java repositories are larger and externalise more roles than the Python ones, so the two languages are not directly comparable. We do not yet investigate how the approach performs on other pattern in the Van De Berg's catalogues, or on other web frameworks such as Django or Express, or on languages for which we have no traversal rules, but will consider that in future works. Our two annotators are experienced web developers rather than the architects of the systems, which is the standard limitation of groundtruths built with an authoritative protocol [29].

VII. Related Work

A. Automated Software Architecture Recovery

Software architecture recovery is a well-studied field [22], [43], but existing methods are hard to adapt to security pattern recovery. Traditional static methods cluster code entities with human-specified graph rules [44]–[46], which limits their generalizability to modern codebases across languages and libraries. Learning-based methods learn the representation of code entities [47] or semantic features of their dependency graphs [48], [49], which partially solves generalization, but still gives an inductive view of the architecture, not suitable for security patterns, which are prescriptive and enforceable.

Deductive software architecture recovery instead leverages the reasoning of LLMs to recover the architecture of a codebase against a reference architecture [17], [21], [50], [51], which suits the prescriptive nature of security patterns. However, these works only recover the component view of the architecture, not the interaction view, which is crucial for security patterns. Our work is the first deductive approach that recovers both views of security patterns from source code, evaluated on a large dataset of real-world codebases.

B. Evaluating Architecture Recovery Correctness

To measure the correctness of automated architecture recovery, traditional cluster-based recovery methods rely on the distance between the recovered clusters and those of a groundtruth architecture [22], [23], [29]. Since our method is deductive, mapping the roles of a given pattern to code rather than grouping the code into clusters, these distance-based measures are not suitable for our evaluation. Other works focus on measuring architectural drift, to analyze whether an implementation conforms to its intended design or architecture [52]–[54]. Reflexion models, for example, compare an engineer's high-level model with a model extracted from the source code, and report where the two diverge [5]. Pruijt et al. compare the accuracy of ten tools that check such conformance [55], and commercial platforms such as Sonar also offer these checks, but they are proprietary and not open-source [56]. However, measuring conformance is also not suitable for our evaluation, as we measure the independent tasks of security pattern recovery, which we have divided into mapping security-relevant code [42] and arranging their interactions in sequence [57].

C. Mining Security Architectural Tactics

Works on mining security architectural tactics are close to ours, as they share our motivation of mining the architecture-relevant code that enables the security properties of software [58]–[60]. Mirakhorli and Cleland-Huang detect tactic-related code in open-source systems and monitor it as the system evolves [58]. Mujhid et al. build ArchEngine, a search engine that retrieves and ranks the code snippets implementing a given tactic [59]. Santos et al. catalogue 224 security architecture weaknesses, organized by the security tactics that address them [60]. Like SecPatRec, these works mine code with lexical code search, using API signatures as keywords. However, they do not attempt to tackle the mapping of the mined code snippets to the architectural components of the security tactics or patterns, which is the core of our recovery task.

VIII. Conclusion

We presented SecPatRec, a hybrid approach to security pattern recovery that combines an LLM agent with code search for role mapping and CPG analysis for interaction recovery. On 100 instances across 93 Java and Python codebases, it achieves a mean RDA of 0.84, MLS of 0.84 and IRC of 0.66 over four LLMs, outperforming a one-shot LLM baseline at a cost that barely grows with codebase size. As the CPG analysis is nearly exact when the roles are mapped exactly, improving role mapping is the key to further improvement. Our dataset, metrics and pipeline can serve as a benchmark and an instrument for mining security patterns at scale.

REFERENCES

[1] I. Arce, K. Clark-Fisher, N. Daswani, J. DelGrosso, D. Dhillon, C. Kern, T. Kohno, C. Landwehr, G. McGraw, B. Schoenfield, M. Seltzer, D. Spinellis, I. Tarandach, and J. West, "Avoiding the top 10 software security design flaws," IEEE Computer Society Center for Secure Design, Tech. Rep., 2014.

[2] G. McGraw, *Software Security: Building Security In*, 1st ed. Upper Saddle River, NJ: Addison-Wesley Professional, Jan. 2006.

[3] J. Yoder and J. Barcalow, "Architectural Patterns for Enabling Application Security," in *Proceedings of the 4th Conference on Patterns Language of Programming (PLoP '97)*, 1997.

[4] European Parliament and Council of the European Union, "Regulation (EU) 2024/2847 of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act)," http://data.europa.eu/eli/reg/2024/2847/oj, Nov. 2024.

[5] G. C. Murphy, D. Notkin, and K. Sullivan, "Software reflexion models: bridging the gap between source and high-level models," *SIGSOFT Softw. Eng. Notes*, vol. 20, no. 4, pp. 18–28, Oct. 1995. [Online]. Available: https://dl.acm.org/doi/10.1145/222132.222136

[6] T. W. Thomas, M. Tabassum, B. Chu, and H. Lipford, "Security During Application Development: an Application Security Expert Perspective," in *Proceedings of the 2018 CHI Conference on Human Factors in Computing Systems*, ser. CHI '18. New York, NY, USA: Association for Computing Machinery, Apr. 2018, pp. 1–12. [Online]. Available: https://dl.acm.org/doi/10.1145/3173574.3173836

[7] N. A. Ernst and M. P. Robillard, "A Study of Documentation for Software Architecture," *Empirical Software Engineering*, vol. 28, no. 5, p. 122, 2023.

[8] O. Levy and D. G. Feitelson, "Understanding Large-Scale Software Systems: Structure and Flows," *Empirical Software Engineering*, vol. 26, no. 3, 2021.

[9] R. Scandariato, K. Yskout, T. Heyman, and W. Joosen, "Architecting software with security patterns," Department of Computer Science, KU Leuven, Leuven, Belgium, Tech. Rep., 2008.

[10] M. Schumacher, E. Fernandez-Buglioni, D. Hybertson, F. Buschmann, and P. Sommerlad, *Security Patterns: Integrating Security and Systems Engineering*, ser. Wiley Software Patterns Series. Wiley, 2006. [Online]. Available: https://books.google.com.vn/books?id=T57rfpDko0YC

[11] A. Van Den Berghe, K. Yskout, and W. Joosen, "A reimagined catalogue of software security patterns," in *Proceedings of the 3rd International Workshop on Engineering and Cybersecurity of Critical Systems*. Pittsburgh Pennsylvania: ACM, May 2022, pp. 25–32. [Online]. Available: https://dl.acm.org/doi/10.1145/3524489.3527301

[12] E. Gamma, R. Helm, R. Johnson, and J. Vlissides, *Design Patterns: Elements of Reusable Object-Oriented Software*, ser. Addison-Wesley Professional Computing Series. Pearson Education, 1994. [Online]. Available: https://books.google.ie/books?id=6oHuKQe3TjQC

[13] M. VanHilst and E. B. Fernandez, "Reverse Engineering to Detect Security Patterns in Code," in *Proceedings of the 1st International Workshop on Software Patterns and Quality (SPAQu'07)*, Nagoya, Japan, 2007.

[14] A. Behrens, "What are Security Patterns?: A Formal Model for Security and Design of Software," in *Proceedings of the 13th International Conference on Availability, Reliability and Security*. Hamburg Germany: ACM, Aug. 2018, pp. 1–6. [Online]. Available: https://dl.acm.org/doi/10.1145/3230833.3230834

[15] K. Yskout, R. Scandariato, and W. Joosen, "Does organizing security patterns focus architectural choices?" in *Proceedings of the 34th International Conference on Software Engineering*, ser. ICSE '12. Zurich, Switzerland: IEEE Press, Jun. 2012, pp. 617–627.

[16] ——, "Do Security Patterns Really Help Designers?" in *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, vol. 1, May 2015, pp. 292–302. [Online]. Available: https://ieeexplore.ieee.org/abstract/document/7194582

[17] S. A. Rukmono, L. Ochoa, and M. Chaudron, "Deductive Software Architecture Recovery via Chain-of-thought Prompting," in *Proceedings of the 2024 ACM/IEEE 44th International Conference on Software Engineering: New Ideas and Emerging Results*. Lisbon Portugal: ACM, Apr. 2024, pp. 92–96. [Online]. Available: https://dl.acm.org/doi/10.1145/3639476.3639776

[18] M. Bunke and K. Sohr, "An Architecture-Centric Approach to Detecting Security Patterns in Software," in *Engineering Secure Software and Systems*, U. Erlingsson, R. Wieringa, and N. Zannone, Eds. Berlin, Heidelberg: Springer Berlin Heidelberg, 2011, vol. 6542, pp. 156–166, series Title: Lecture Notes in Computer Science. [Online]. Available: http://link.springer.com/10.1007/978-3-642-19125-1_12

[19] A. K. Alvi and M. Zulkernine, "A security pattern detection framework for building more secure software," *Journal of Systems and Software*, vol. 171, p. 110838, Jan. 2021. [Online]. Available: https://linkinghub.elsevier.com/retrieve/pii/S0164121220302296

[20] M. Bunke and K. Sohr, "Towards supporting software assurance assessments by detecting security patterns," *Software Quality Journal*, vol. 28, no. 4, pp. 1711–1753, 2020.

[21] S. A. Rukmono, L. Ochoa, T. Bressers, J. Krüger, and M. Chaudron, "Evaluating Explanatory Artefacts of DSAR-Recovered Software Architectures from Industrial Codebases," in *Proceedings of the 34th ACM International Conference on the Foundations of Software Engineering*, ser. FSE Companion '26. New York, NY, USA: Association for Computing Machinery, Jul. 2026, pp. 880–891. [Online]. Available: https://dl.acm.org/doi/10.1145/3803437.3805259

[22] J. Garcia, I. Ivkovic, and N. Medvidovic, "A comparative analysis of software architecture recovery techniques," in *2013 28th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, Nov. 2013, pp. 486–496. [Online]. Available: https://ieeexplore.ieee.org/document/6693106/

[23] T. Lutellier, D. Chollak, J. Garcia, L. Tan, D. Rayside, N. Medvidović, and R. Kroeger, "Measuring the Impact of Code Dependencies on Software Architecture Recovery Techniques," *IEEE Transactions on Software Engineering*, vol. 44, no. 2, pp. 159–181, Feb. 2018. [Online]. Available: https://ieeexplore.ieee.org/document/7859416/

[24] F. Yamaguchi, N. Golde, D. Arp, and K. Rieck, "Modeling and Discovering Vulnerabilities with Code Property Graphs," in *2014 IEEE Symposium on Security and Privacy*, May 2014, pp. 590–604, iSSN: 2375-1207. [Online]. Available: https://ieeexplore.ieee.org/document/6956589/

[25] M. Schumacher, *Security Engineering with Patterns*, ser. Lecture Notes in Computer Science, G. Goos, J. Hartmanis, and J. Van Leeuwen, Eds. Berlin, Heidelberg: Springer Berlin Heidelberg, 2003, vol. 2754. [Online]. Available: http://link.springer.com/10.1007/b11930

[26] E. Fernandez-Buglioni, *Security Patterns in Practice: Designing Secure Architectures Using Software Patterns*. Chichester, West Sussex: Wiley, 2013.

[27] L. Bass, P. Clements, and R. Kazman, *Software Architecture in Practice, 4th Edition*, 2021. [Online]. Available: https://www.oreilly.com/library/view/software-architecture-in/9780136885979/

[28] R. Wirfs-Brock and A. McKean, *Object Design: Roles, Responsibilities, and Collaborations*. Pearson Education, Oct. 2002.

[29] J. Garcia, I. Krka, C. Mattmann, and N. Medvidovic, "Obtaining ground-truth software architectures," in *Proceedings of the 2013 International Conference on Software Engineering*, ser. ICSE '13. San Francisco, CA, USA: IEEE Press, May 2013, pp. 901–910. [Online]. Available: https://dl.acm.org/doi/10.5555/2486788.2486911

[30] S. Ramírez, "FastAPI documentation: OAuth2 with password, bearer with JWT tokens," https://fastapi.tiangolo.com/tutorial/security/oauth2-jwt/, 2026.

[31] H. Xu, S. Wang, N. Li, K. Wang, Y. Zhao, K. Chen, T. Yu, Y. Liu, and H. Wang, "Large Language Models for Cyber Security: A Systematic Literature Review," *ACM Transactions on Software Engineering and Methodology*, Sep. 2025, just Accepted. [Online]. Available: https://dl.acm.org/doi/10.1145/3769676

[32] M. Le-Anh, H. Nguyen, A. K. Tran, N. Le Hai, L. N. Van, N. D. Bui, and B. Le, "Do Not Treat Code as Natural Language: Implications for Repository-Level Code Generation and Beyond," *Proceedings of the ACM on Software Engineering*, vol. 3, no. FSE, pp. FSE017:366–FSE017:389, Jun. 2026. [Online]. Available: https://dl.acm.org/doi/10.1145/3797144

[33] M. Nguyen, "SpareCodeSearch: Searching for Code Context When You Have No Spare GPU," in *2025 40th IEEE/ACM International Conference on Automated Software Engineering Workshops (ASEW)*. IEEE Press, Nov. 2025, pp. 364–367. [Online]. Available: https://dl.acm.org/doi/10.1109/ASEW67777.2025.00073

[34] S. Yao, J. Zhao, D. Yu, N. Du, I. Shafran, K. Narasimhan, and Y. Cao, "ReAct: Synergizing Reasoning and Acting in Language Models," in *The Eleventh International Conference on Learning Representations (ICLR)*, 2023. [Online]. Available: https://openreview.net/forum?id=WE_vluYUL-X

[35] S. Xiao, Z. Liu, P. Zhang, N. Muennighoff, D. Lian, and J.-Y. Nie, "C-Pack: Packed resources for general Chinese embeddings," in *Proceedings of the 47th International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2024, pp. 641–649.

[36] D. Nguyen, L. Nam, A. Dau, A. Nguyen, K. Nghiem, J. Guo, and N. Bui, "The Vault: A Comprehensive Multilingual Dataset for Advancing Code Understanding and Generation," in *Findings of the Association for Computational Linguistics: EMNLP 2023*, H. Bouamor, J. Pino, and K. Bali, Eds. Singapore: Association for Computational Linguistics, Dec. 2023, pp. 4763–4788. [Online]. Available: https://aclanthology.org/2023.findings-emnlp.316

[37] Jetbrains, "The State of Java 2025." [Online]. Available: https://lp.jetbrains.com/the-state-of-java-2025

[38] ——, "The State of Python 2025: Trends and Survey Insights," Aug. 2025, section: Data Science. [Online]. Available: https://blog.jetbrains.com/pycharm/2025/08/the-state-of-python-2025/

[39] OWASP, "OWASP Top 10:2025." [Online]. Available: https://owasp.org/Top10/2025/

[40] H. Kim, K. Mitra, R. Li Chen, S. Rahman, and D. Zhang, "MEGAnno+: A Human-LLM Collaborative Annotation System," in *Proceedings of the 18th Conference of the European Chapter of the Association for Computational Linguistics: System Demonstrations*, N. Aletras and O. De Clercq, Eds. St. Julians, Malta: Association for Computational Linguistics, Mar. 2024, pp. 168–176. [Online]. Available: https://aclanthology.org/2024.eacl-demo.18/

[41] T. Ahmed, P. Devanbu, C. Treude, and M. Pradel, "Can LLMs Replace Manual Annotation of Software Engineering Artifacts?" in *2025 IEEE/ACM 22nd International Conference on Mining Software Repositories (MSR)*, Apr. 2025, pp. 526–538, iSSN: 2574-3864. [Online]. Available: https://ieeexplore.ieee.org/abstract/document/11025652

[42] H. Cleve and A. Zeller, "Locating causes of program failures," in *Proceedings of the 27th international conference on Software engineering*, ser. ICSE '05. New York, NY, USA: Association for Computing Machinery, May 2005, pp. 342–351. [Online]. Available: https://dl.acm.org/doi/10.1145/1062455.1062522

[43] S. Ducasse and D. Pollet, "Software Architecture Reconstruction: A Process-Oriented Taxonomy," *IEEE Transactions on Software Engineering*, vol. 35, no. 4, pp. 573–591, Jul. 2009. [Online]. Available: http://ieeexplore.ieee.org/document/4815276/

[44] B. Mitchell and S. Mancoridis, "On the automatic modularization of software systems using the Bunch tool," *IEEE Transactions on Software Engineering*, vol. 32, no. 3, pp. 193–208, Mar. 2006. [Online]. Available: https://ieeexplore.ieee.org/document/1610610/

[45] S. Mancoridis, B. Mitchell, Y. Chen, and E. Gansner, "Bunch: a clustering tool for the recovery and maintenance of software system structures," in *Proceedings IEEE International Conference on Software Maintenance - 1999 (ICSM'99). 'Software Maintenance for Business Change' (Cat. No.99CB36360)*. Oxford, UK: IEEE, 1999, pp. 50–59. [Online]. Available: http://ieeexplore.ieee.org/document/792498/

[46] K. Sartipi, "Software architecture recovery based on pattern matching," in *International Conference on Software Maintenance, 2003. ICSM 2003. Proceedings.*, Sep. 2003, pp. 293–296, iSSN: 1063-6773. [Online]. Available: https://ieeexplore.ieee.org/document/1235434/

[47] J. Garcia, D. Popescu, C. Mattmann, N. Medvidovic, and Y. Cai, "Enhancing architectural recovery using concerns," in *2011 26th IEEE/ACM International Conference on Automated Software Engineering (ASE 2011)*, Nov. 2011, pp. 552–555, iSSN: 1938-4300. [Online]. Available: https://ieeexplore.ieee.org/document/6100123/

[48] Y. Zhang, Z. Xu, C. Liu, H. Chen, J. Sun, D. Qiu, and Y. Liu, "Software Architecture Recovery with Information Fusion," Nov. 2023. [Online]. Available: http://arxiv.org/abs/2311.04643

[49] N. D. Q. Bui, Y. Yu, and L. Jiang, "TreeCaps: Tree-Based Capsule Networks for Source Code Processing," *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 35, no. 1, pp. 30–38, May 2021. [Online]. Available: https://ojs.aaai.org/index.php/AAAI/article/view/16074

[50] W. Zhao, W. Jin, Y. Zhang, M. Fan, H. Wang, L. Li, Y. Liu, and T. Liu, "Software Architecture Recovery Augmented With Semantics," *IEEE Transactions on Software Engineering*, vol. 52, no. 1, pp. 338–359, Jan. 2026. [Online]. Available: https://ieeexplore.ieee.org/document/11203255/

[51] D. Amalfitano, M. De Luca, T. Santilli, P. Pelliccione, and A. R. Fasolino, "Automated Software Architecture Design Recovery from Source Code Using LLMs," in *Software Architecture*, V. Andrikopoulos, C. Pautasso, N. Ali, J. Soldani, and X. Xu, Eds. Cham: Springer Nature Switzerland, 2026, pp. 73–89.

[52] L. De Silva and D. Balasubramaniam, "Controlling software architecture erosion: A survey," *Journal of Systems and Software*, vol. 85, no. 1, pp. 132–151, Jan. 2012. [Online]. Available: https://linkinghub.elsevier.com/retrieve/pii/S0164121211002044

[53] J. Rosik, A. Le Gear, J. Buckley, M. A. Babar, and D. Connolly, "Assessing architectural drift in commercial software development: a case study," *Software: Practice and Experience*, vol. 41, no. 1, pp. 63–86, 2011, _eprint: https://onlinelibrary.wiley.com/doi/pdf/10.1002/spe.999. [Online]. Available: https://onlinelibrary.wiley.com/doi/abs/10.1002/spe.999

[54] F. Zamfirov, A. Radulescu, J. Krüger, and M. R. V. Chaudron, "Lessons from Visualizing Software Architecture Structure Conformance at Thermo Fisher Scientific," in *Software Engineering and Advanced Applications: 51st Euromicro Conference, SEAA 2025, Salerno, Italy, September 10–12, 2025, Proceedings, Part III*. Berlin, Heidelberg: Springer-Verlag, Sep. 2025, pp. 372–389. [Online]. Available: https://doi.org/10.1007/978-3-032-04207-1_25

[55] L. Pruijt, C. Köppe, J. M. Van Der Werf, and S. Brinkkemper, "The accuracy of dependency analysis in static architecture compliance checking: The Accuracy of Dependency Analysis in Static ACC," *Software: Practice and Experience*, vol. 47, no. 2, pp. 273–309, Feb. 2017. [Online]. Available: https://onlinelibrary.wiley.com/doi/10.1002/spe.2421

[56] Curlee, "The architecture gap: Why your code becomes hard to change \textbar Sonar," Feb. 2026. [Online]. Available: https://www.sonarsource.com/blog/the-architecture-gap-why-your-code-becomes-hard-to-change

[57] M. Lapata, "Automatic Evaluation of Information Ordering: Kendall's Tau," *Computational Linguistics*, vol. 32, no. 4, pp. 471–484, 2006. [Online]. Available: https://aclanthology.org/J06-4002/

[58] M. Mirakhorli and J. Cleland-Huang, "Detecting, Tracing, and Monitoring Architectural Tactics in Code," *IEEE Transactions on Software Engineering*, vol. 42, no. 3, pp. 205–220, Mar. 2016.

[59] I. J. Mujhid, J. C. S. Santos, R. Gopalakrishnan, and M. Mirakhorli, "A search engine for finding and reusing architecturally significant code," *Journal of Systems and Software*, vol. 130, pp. 81–93, Aug. 2017.

[60] J. C. S. Santos, K. Tarrit, and M. Mirakhorli, "A Catalog of Security Architecture Weaknesses," in *2017 IEEE International Conference on Software Architecture Workshops (ICSAW)*, Apr. 2017, pp. 220–223. [Online]. Available: https://ieeexplore.ieee.org/document/7958491

APPENDIX A
EXTRA TECHNICAL DETAILS

A. The ADL Code Generator

SECPATREC reads every security pattern through a single artefact, the specification $P = (R, B)$. Security patterns, however, are documented in different ways: each catalogue represents a pattern's structure in its own form of prose and diagrams [10], [11], [26], which the pipeline cannot read directly. An ADL code generator is therefore needed to bring a pattern into the structure the pipeline understands. This appendix presents one such case: transforming the patterns of the KU Leuven catalogue [11] into P. Figure 6 follows *Password-based authentication* (P1), the pattern of Figure 1, through the generator's six stages.

1) The KU Leuven Catalogue: Each pattern of the KU Leuven catalogue is documented on one page, in the same parts:

- *Name, Summary*: what the pattern is and what it achieves.
- *Parent, Problem*: the general pattern it refines and the problem it solves.
- *Roles*: the participants, each with a metamodel type.
- *Actions, Data elements*: the calls and data the roles exchange.
- *Behaviour*: the interactions between roles, as numbered steps.
- *Diagram*: the same interactions, drawn as boxes and numbered arrows.
- *Considerations, Implementations, References*: design advice, example libraries and literature.

Our main concern is the pattern's structure: the Name, Summary, Roles, Actions, Data elements, Behaviour and the diagram (Figure 7). The other parts guide a designer but define no role or interaction, so the generator keeps them only as context.

A pattern's diagram usually holds several flows: beside the main flow, which carries the core idea of the pattern, it draws lifecycle flows such as registration and password reset (P1 has all three). Our concern is the main flow, so the generator includes a component that selects it (*Select*, below). The other flows are not lost: without this component, the generator keeps every flow.

2) Stages: The generator turns these parts into P in six stages (Figure 6). Fetching the page and normalising the result are deterministic; the four stages between them are model calls, each with a fixed prompt (Section A-A3), on one pinned model, GPT-6 Sol, independent of the models under study (Section IV-D). Each stage writes its result to disk, so an error in P can be traced to the stage that introduced it.

Fetch. An HTML parser renders the catalogue page as Markdown, keeping its *Roles*, *Actions*, *Data elements* and *Behaviour* sections apart, strips the site's navigation and references, and downloads the diagram image. For P1, the page names fourteen roles and narrates fifteen numbered steps.

Transcribe. A vision call transcribes the diagram into one Mermaid[16] flowchart: one node per box and one edge per arrow, each label kept verbatim with its step prefix. The prompt has the model read each direction off the arrowhead and emit exactly one edge per step number. P1's flowchart has 14 nodes and 38 edges.

Split and select. A text-only call groups the edges by step-prefix family (`1..N`, `Reg.*`, `Res.*`) into one sequence diagram each, and a second call keeps only the pattern's primary runtime flow. For P1, this keeps the login flow (steps 1–15) and drops registration and reset, together with five roles no login invokes: the Registrar, Password policy, Hash manager, SRNG and Resetter.

Synthesise. A text-only call with reasoning emits P from the page prose and the main flow: each role with its name, metamodel type, `required` flag and description, and each interaction with its `from` and `to` roles, call `element` and description. Its central rule is that *an entry is an interaction, not an arrow*: a response is folded into the request it answers, as a sentence of its description, so P1's 16 arrows become the nine interactions $b_1, \ldots, b_9$ of Figure 1 (Figure 8). A returning edge that answers no request, such as the System's reply to the Subject, keeps its own entry of kind `data`.

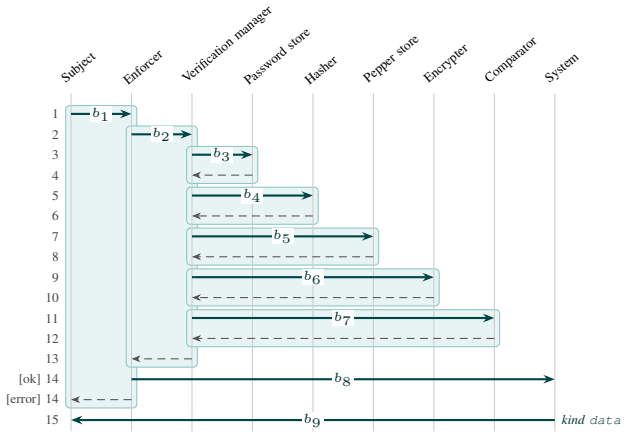


Fig. 8. Folding P1's main flow. Its 16 arrows become the nine interactions $b_1, \ldots, b_9$ of Figure 1: each response (dashed) is folded into the request it answers, and a band spans the interaction from one to the other. The bands nest like a call stack. The System's reply opens no band, since the Subject never called the System, and stays as b_9.

Normalise. Deterministic passes enforce the prompt's rules on the returned JSON: they fold any response the model left as its own entry, renumber the steps $1, \ldots, N$, drop roles that no interaction uses, and mark the initiating party and the protected System as not required.

The four artefacts of every pattern are released with our dataset, so each specification can be checked against the catalogue page it was compiled from.

3) Prompts: Figures 9–12 reproduce the prompts of the four model calls verbatim, as they appear in the generator's source. Each pairs a system prompt, fixed across patterns, with the template of its per-run user message, whose placeholders

[16] https://mermaid.js.org

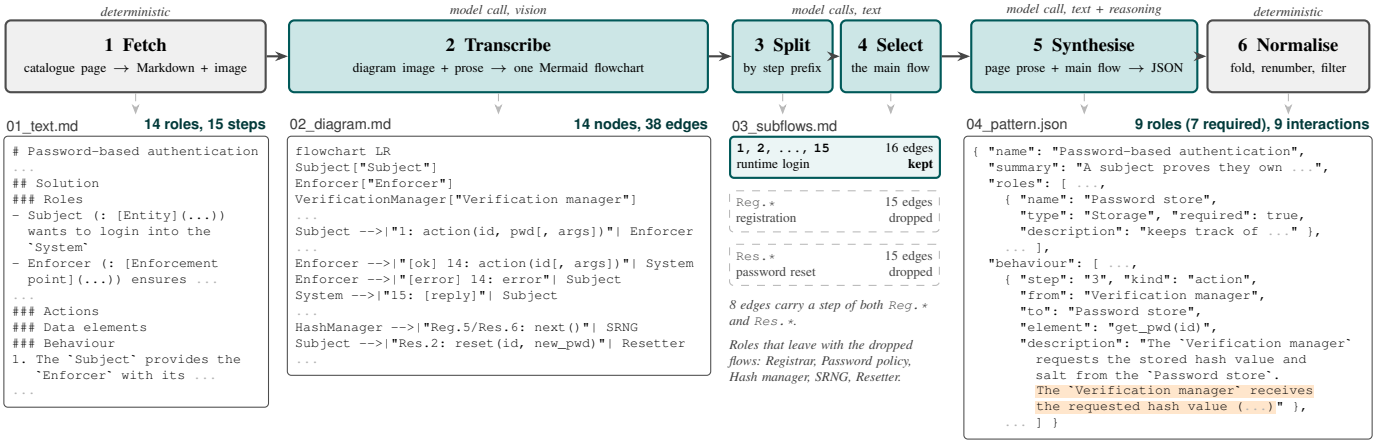


Fig. 6. The ADL code generator on *Password-based authentication* (P1). Top: the six stages, grey where deterministic and tinted where a model call. Bottom: the artefact each stage writes, as verbatim excerpts (prose re-wrapped, runs elided). Stage 5 reads the page prose as well as the main flow; in its output, a response survives only as a sentence appended to the request it answers (shaded).

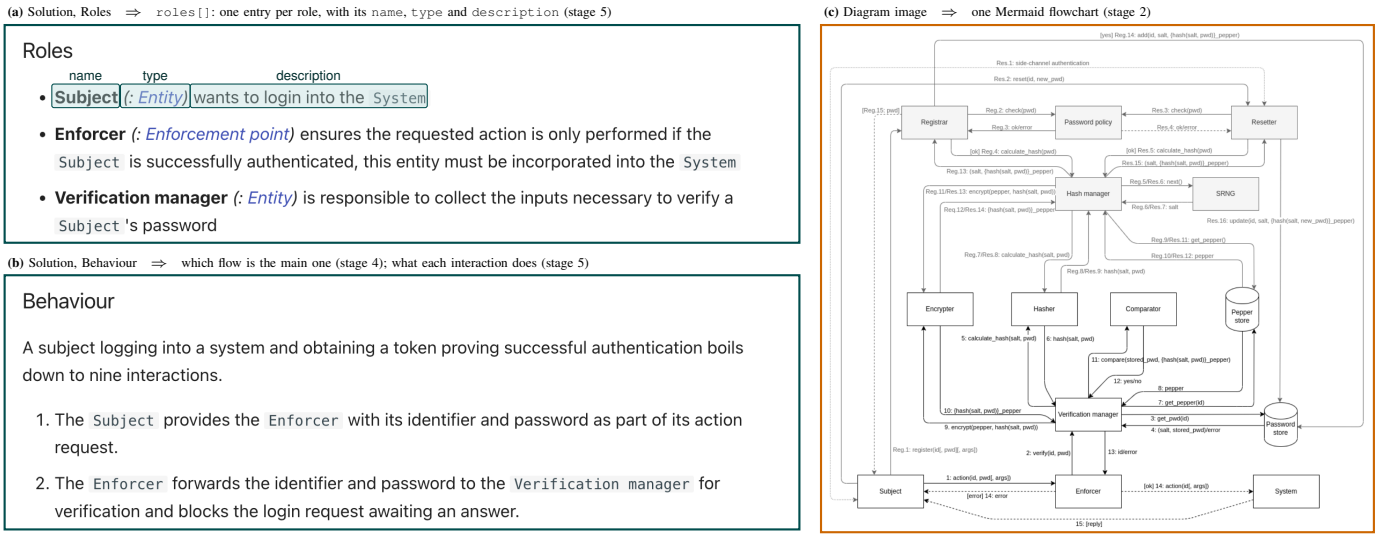


Fig. 7. The parts of the catalogue page of *Password-based authentication* [11] that the generator reads, captured on 24 October 2026: (a) the roles, with the name, metamodel type and description of the first one marked; (b) the numbered walkthrough; and (c) the diagram image. The page's name, summary, actions and data elements are read as well. Screenshots © imec-DistriNet, CC BY-NC-SA 4.0.

are filled from the catalogue page (`name`, `text`) and from the previous stage's output (`mermaid`, `catalogue`).

System prompt

```
You are a diagram transcription expert. You are given a single diagram image from the DistriNet (KU Leuven)
security-pattern catalogue together with the pattern's description text. The image is the authoritative depiction of the
pattern.

These images are box-and-arrow collaboration diagrams (roles drawn as boxes, connected by numbered message arrows) --
NOT lifeline sequence diagrams. Transcribe the WHOLE diagram into ONE Mermaid `flowchart` (graph) that reproduces the
image completely -- every element, nothing added, nothing left out. Do NOT split it into separate diagrams and do NOT
use `sequenceDiagram`.

Represent the image as a graph:
- One NODE per role / participant / box, with a valid single-token id and a bracketed label holding the real (possibly
multi-word) name: `Enforcer["Enforcer"]`, `PasswordStore["Password store"]`.
- One directed EDGE per arrow, labelled with the arrow's EXACT message text INCLUDING its full step prefix/number (`1.`,
`Reg.2`, `Res.4`, ...): `Subject -->|"1. action(id, pwd[])"| Enforcer`.

Follow this METHOD so that no edge is missed and every direction is correct:
1. First, list every box (role) in the image. Create one node for each.
2. Then walk the arrows IN STEP-NUMBER ORDER (1, 2, 3 ... then `Reg.1`, `Reg.2` ... then `Res.1`, `Res.2` ...). Every
step number visible in the image MUST become exactly one edge -- if you see labels up to 15, you must output 15 numbered
edges, with none skipped and none duplicated.
3. For EACH arrow determine its direction by the ARROWHEAD: the edge goes FROM the box at the arrow's tail TO the box
the arrowhead points at. Write `Source -->|"label"| Target` in exactly that direction. A reply/return arrow points back
the other way -- keep it as its own edge in its own direction. Do not guess direction from left/right position; read the
arrowhead. When unsure, cross-check the numbered step against the PATTERN DESCRIPTION, which states who sends each
message to whom.
4. Include return/response arrows, guards/conditions (e.g. `[ok]`, `[error]`), and any notes (add a note as its own node
or fold it into the relevant edge label).
5. Before finishing, re-scan the image and confirm every arrow you can see has a matching edge and that each edge's
endpoints and direction match the arrowhead.

Preserve label wording exactly as shown; do NOT summarise, merge two arrows into one, rename, or invent anything. If
some text is partly illegible, transcribe your best reading.

Mermaid rules: start with `flowchart LR` (or `flowchart TD`). Node ids must be single tokens with NO spaces -- always
put the readable name in a bracketed `["..."]` label. ALWAYS wrap edge labels in double quotes because they contain
digits, dots, parentheses, and commas: `A -->|"..."| B`.

Output ONLY the Mermaid source, starting with `flowchart`. No prose, no code fences.
```

User message (template)

```
Pattern: {name}.

--- PATTERN DESCRIPTION ---
{text}
--- END PATTERN DESCRIPTION ---

Transcribe the ENTIRE attached diagram into one complete Mermaid `flowchart` now: one node per role/box, one directed
edge per arrow, every edge label (with its step prefix/number) quoted and exact. Capture every node, every arrow, and
every label -- do not miss any detail.
```

Fig. 9. The prompt of stage 2, Transcribe (vision call): diagram image + page prose → one Mermaid flowchart. The diagram is attached to the user message as an image.

System prompt

```
You are given the full Mermaid `flowchart` transcription of a security pattern's diagram (roles as nodes, numbered
messages as directed edges) plus the pattern's description text. This is a TEXT task -- work only from the flowchart;
there is no image.

Every edge label starts with a step PREFIX -- a number or tag such as `1.`, `2.`, `Reg.2`, or `Res.4`. Edges that share a
prefix family (`1..N`, `Reg.*`, `Res.*`, ...) form ONE sub-flow.

A family is decided by the prefix ALONE, never by topic. Plainly numbered edges `1`, `2`, `3`, ... `N` are ONE single
family however many they are and however many different roles they touch -- they are the consecutive steps of one
walkthrough, so NEVER cut a plain numeric chain into thematic groups ("verification", "enforcement", "update", ...). A
new family starts only at a distinct non-numeric tag (`Reg.*`, `Res.*`, `A.*`, ...) or a restart of the numbering. Branch
conditions and repeats do not start a family either: `[allow] 9: ...` and `[block] 9: Error` are both step 9 of the
numeric family. An edge with NO step prefix at all (e.g. a dotted `Policy changes` annotation) belongs to no family --
leave it out entirely.

Do the following:
1. Group the flowchart's edges into sub-flows by their prefix family.
2. For each sub-flow emit a Mermaid `sequenceDiagram` containing exactly that family's edges, ordered by step number.
Convert each directed edge `A -->|"n: msg"| B` into a message `A->>B: n: msg`, preserving the flowchart's direction
EXACTLY (source → target). Use `-->>` when the label is clearly a reply/return/response, otherwise `->>`. Keep EVERY
edge of the family -- none may be dropped, merged, or duplicated -- with its label verbatim.
3. Give each sub-flow a short descriptive NAME grounded in the description (e.g. "Runtime authentication", "Subject
registration", "Password reset") -- never a generic "Flow 1".

Participant ids must be single Mermaid-valid tokens with NO spaces; for a multi-word node name use an alias --
`participant PasswordStore as Password store` -- and reference the id in every message. Do NOT rename roles or invent
edges. If the flowchart has only one prefix family, return a single sub-flow.

Output ONLY a JSON object of exactly this shape -- no prose, no code fences:
{"subflows": [{"name": "<human name>", "prefix": "<edge prefix>", "mermaid": "<Mermaid source>"}]}
```

User message (template)

```
--- PATTERN DESCRIPTION ---
{text}
--- END PATTERN DESCRIPTION ---

--- FULL DIAGRAM (Mermaid flowchart) ---
{mermaid}
--- END FULL DIAGRAM ---

Split the flowchart into sub-flows by edge-prefix family, name each from the description, and return the JSON now. Every
PREFIXED edge in the flowchart must appear in exactly one sub-flow, with its label and direction unchanged.
```

Fig. 10. The prompt of stage 3, Split (text-only): flowchart → one sequence diagram per step-prefix family.

System prompt

```
You are a security-pattern analyst. You are given a pattern's description text and a numbered list of candidate
sub-flows extracted from its diagram. Exactly ONE of them is the MAIN flow -- the core interaction the pattern is
fundamentally about, i.e. the primary runtime behaviour laid out in the description's main 'Solution' / 'Behaviour'
narrative (the numbered steps). The others are auxiliary or lifecycle flows (e.g. registration, password change / reset,
key rotation, provisioning, setup).

Choose the single sub-flow that best corresponds to that main behaviour. Judge by the sub-flow names and edge prefixes
against the description -- the main flow is the one whose messages match the description's principal numbered
walkthrough.

Output ONLY JSON, no prose, no code fences: {"index": <zero-based index of the main sub-flow>}
```

User message (template)

```
--- PATTERN DESCRIPTION ---
{text}
--- END PATTERN DESCRIPTION ---

Candidate sub-flows (index. name -- edge prefix):
{catalogue}

Which one is the MAIN flow described by the text? Return {"index": n}.
```

Fig. 11. The prompt of stage 4, Select (text-only): candidate sub-flows → the index of the main flow.

System prompt

```
You are a security-pattern analyst. From a DistriNet security pattern's cleaned text (`Roles`, `Actions`, `Data
elements`, `Behaviour`) and the Mermaid diagram of its MAIN flow, produce the pattern's canonical JSON. Copy names and
wording from the text; never invent anything.

An entry in `behaviour` is an INTERACTION, not an arrow. The request edge `A → B` and the response edge `B → A`
answering it share ONE entry -- the request's, in the requester's direction -- with the response's sentence appended to
its `description`, so the entry states what was asked and what came back. The response gets no entry and no field of its
own. Pair them like a call stack: a response answers the most recent unanswered request between those two roles, so it
may be several steps later. Example -- arrows `1 Subject→Enforcer: action(token)`, `2 Enforcer→Verifier:
verify(token)`, `3 Verifier→Store: get_principal(token)`, `4 Store→Verifier: principal/error`, `5 Verifier→Enforcer:
principal/error`, `6 Enforcer→System: action(principal)` → four entries (1, 2, 3, 6), with 4 folded into 3 and 5 into
2. This includes the flow's closing `reply`/`error` back to the initiator. Only a returning edge whose target never made
the request keeps its own entry (`kind: "data"`).

Output ONLY a JSON object:
- "name": the pattern's name; "summary": its `Summary` paragraph (else "").
- "roles": one entry `{"name", "type", "required", "description"}` per role -- `type` is the metamodel type in
parentheses ("Entity", "Storage", ...). Include ONLY roles used as some interaction's `from` or `to`: drop the `Roles`
section's auxiliary-flow roles (registration, reset, provisioning) the main flow never touches, and conversely add a
main-flow participant the section omits (often the protected `System`), describing it from the text. "required" is false
for the `Subject` and the `System` -- the pattern's environment rather than its machinery -- and true for every other
role.
- "behaviour": the main flow's interactions, each `{"step", "from", "to", "kind", "element", "description"}`. `step`
numbers the entries sequentially from "1" -- not the diagram's edge numbers, whose sequence the merging breaks.
`from`/`to` are the requester and responder, read off the request arrow's direction and named exactly as in `roles`.
`kind` is "action" (a call) or "data" (an unfoldable returning edge). `element` is the request arrow's CONCRETE label as
instantiated in the diagram -- `hash(salt, pwd)`, not the `Actions`/`Data elements` section's placeholder `hash(x, y)`;
"" if nothing matches. Every numbered `Behaviour` step is accounted for: a request as an entry, a response inside the
description of the entry it answers.
```

User message (template)

```
--- PATTERN TEXT ---
{text}
--- END PATTERN TEXT ---

--- MAIN FLOW (Mermaid) ---
{mermaid}
--- END MAIN FLOW ---

Return the pattern JSON now -- name, summary, roles[], behaviour[] -- merging each request with the response that
answers it into a single entry, numbered sequentially.
```

Fig. 12. The prompt of stage 5, Synthesise (text-only, with reasoning): page prose + main flow → the specification P.

B. Prompts for Role Detection and Mapping

The agent uses the same system prompt for every pattern, codebase and LLM (Figures 13 and 14, with the line numbers that the captions refer to). The specification P is not part of it: P is sent as the first user message, after a short note that explains its fields (`name`, `summary`, `roles[]` and `behaviour[]`), and it is the only part of the prompt that changes from one run to the next. Section III-B1 describes the ReAct loop and the four tools that the LLM uses to explore the codebase; a fifth tool, `submit_mapping`, returns the final role mapping and ends the run.

```
AGENT_SYSTEM = """\
You are a security pattern analyst. Given a security pattern and a codebase, decide \
which of the pattern's roles the codebase implements, and pin each implemented role to \
the exact code that plays it.

## The loop

Work in ReAct steps — Thought (reason about what you know and what to do next),
Action (one tool call), Observation (its result) — until every role is accounted
for, then call `submit_mapping`, which ends the run.

## How to find the roles

`behaviour[]` is ONE execution path, not a checklist. A codebase usually holds
several flows sharing the same vocabulary; only one is the pattern's, and every
role must sit on it.

- Find the entry point first — the `to` of step 1 — by its `description`: the
  code a request lands on is not automatically it. Where a framework injects a
  guard (dependency, filter, middleware, decorator, interceptor), the guard is the
  role that checks and the handler it guards processes afterwards. This is the
  only role you may find by searching.
- Then walk `behaviour[]` in order: for each step `X → Y`, read X's code and find
  the call that performs the step; what it reaches is Y. Follow non-role helpers
  through — the role is whatever ends up doing the work.
- Every later role must arrive as the callee of a role already grounded; name the
  caller and line in your Thought ("reached from Enforcer's login at
  routes.py:90"). If you cannot, keep tracing. A name-search hit you never saw
  called from the path is not the answer — re-read the previous role instead.
- Off the path means `missing`: work done only where the path never reaches
  (registration, setup, another endpoint) does not play the role — say in
  `notes` where it lives. DO NOT invent entities.
- Cite the declaration of the callable that does the work. For a store or
  registry, cite the handle or accessor the calling role uses at the call site —
  not a model or class declared elsewhere, not a table or field.
- Cite a library call only for the role the path explicitly calls it for: if the
  repo calls `bcrypt.checkpw`, it is the Verifier, not also the Hasher or
  Comparator it may run internally. A role you never see the repo perform is
  `missing`.

Tools (arguments and limits are in each one's schema):

- `list_dir` — recursive tree of a directory.
- `search` — semantic search of the indexed code, returning the source of every
  strong match.
- `grep` — exact text search over the whole repo.
- `read_file` — a real file by path, with line numbers.
```

Fig. 13. The system prompt of the agent (lines 1–48). Four of its five parts are shown here, in order: the task (lines 2–4), the ReAct loop (6–10), how to find the roles (12–39) and the tools (41–47). The fifth part, the expected output, continues in Figure 14. The specification P is not part of the system prompt: it is sent as the first user message.

```
## Expected output — submit_mapping

`role_mappings` holds exactly one row per role in `roles []`, missing ones
included; each row was reached from an earlier one.

```json
{
  "role_mappings": [
    {
      "patternRole": "Enforcer",
      "status": "present",
      "entity": "login",
      "file": "src/api/routes.py",
      "lines": "88",
      "notes": "Entry point; calls authenticate_user at routes.py:90."
    },
    {
      "patternRole": "Verification manager",
      "status": "present",
      "entity": "authenticate_user",
      "file": "src/auth/service.py",
      "lines": "42",
      "notes": "Reached from Enforcer's login at routes.py:90; drives the check."
    },
    {
      "patternRole": "Encrypter",
      "status": "missing",
      "entity": "",
      "file": "",
      "lines": "",
      "notes": "Nothing on the traced path encrypts; the only such code is off-path."
    }
  ]
}
```

- `patternRole` — the role's `name`, spelled exactly as in the pattern JSON.
- `status` — `"present"` (fully implemented by in-repo code), `"external"` (a
  library, framework, or service the repo merely imports, calls, or configures),
  or `"missing"` (no implementation on the traced path).
- `entity` — the bare name the path reaches, as declared or called:
  `"authenticate_user"`, never `"AuthManager.authenticate_user"`. Prefer the
  function or method over its class.
- `file`, `lines` — the repo-relative path and the *single* definition or
  assignment line (`"42"`, never a body span); for an external symbol, the
  import or call site.
- `notes` — which role and line reached this one, and what the code does. For
  `"missing"`, where you looked and where any off-path implementation lives.

`entity`, `file` and `lines` are empty strings only when the role is `"missing"`.
"""
```

Fig. 14. The system prompt of the agent, continued (lines 49–99): the expected output. An example call of `submit_mapping` shows the format of the role mapping, and the list below it explains each field, including which code symbol a role is mapped to and which line of its file is given.

Prompts of the ablation settings. The two settings of RQ4 (Section V-D), each without one of the two search tools, use the same system prompt with that tool taken out of it. Without keyword search, line 46, which lists `grep`, is removed. Without semantic search, lines 44–45, which list `search`, are removed, and two phrases that mention searching are reworded so that they do not point to the missing tool: "by searching" (line 22) becomes "by looking it up directly", and "name-search hit" (line 28) becomes "name-match hit". The rest of the prompt is unchanged.

C. The One-shot Baseline

The one-shot baseline of Section V-C sends the LLM the system prompt of Figure 15 and one user message. The user message holds the specification P and the whole repository, each between two tags: `<pattern>`P`</pattern>`, followed by `<repository>...</repository>`, which lists the directory tree of the repository and then every source file, each marked with its path. The baseline has no tools: the LLM gives its whole answer, the role mapping and the interaction order, in one reply, and the same request is sent to every LLM. A request longer than 900K tokens, counted with the `o200k_base` tokenizer, is not sent; these are the 16 instances over the baseline's input limit.

```
BASELINE_SYSTEM = """You are a security-pattern recovery analyst.

You are given one security pattern as JSON and the full source of one repository.
For every role in the pattern, decide whether the repository implements it and
ground it to the exact code, then give the order those roles interact in when the
repository runs.

Answer with one JSON object of exactly this shape, and nothing else:

{
  "role_mappings": [
    {
      "patternRole": "the pattern's role name, verbatim",
      "status": "present | external | missing",
      "entity": "the code entity's bare declared name",
      "file": "repo-relative path",
      "lines": "the entity's declaration line",
      "notes": "why this code represents the role"
    }
  ],
  "interaction_order": [
    {
      "from": "role that invokes",
      "to": "role it invokes",
      "file": "repo-relative file holding the call site",
      "line": 0,
      "notes": "the call, in a few words"
    }
  ]
}

"role_mappings" holds one entry per role in the pattern, none left out:

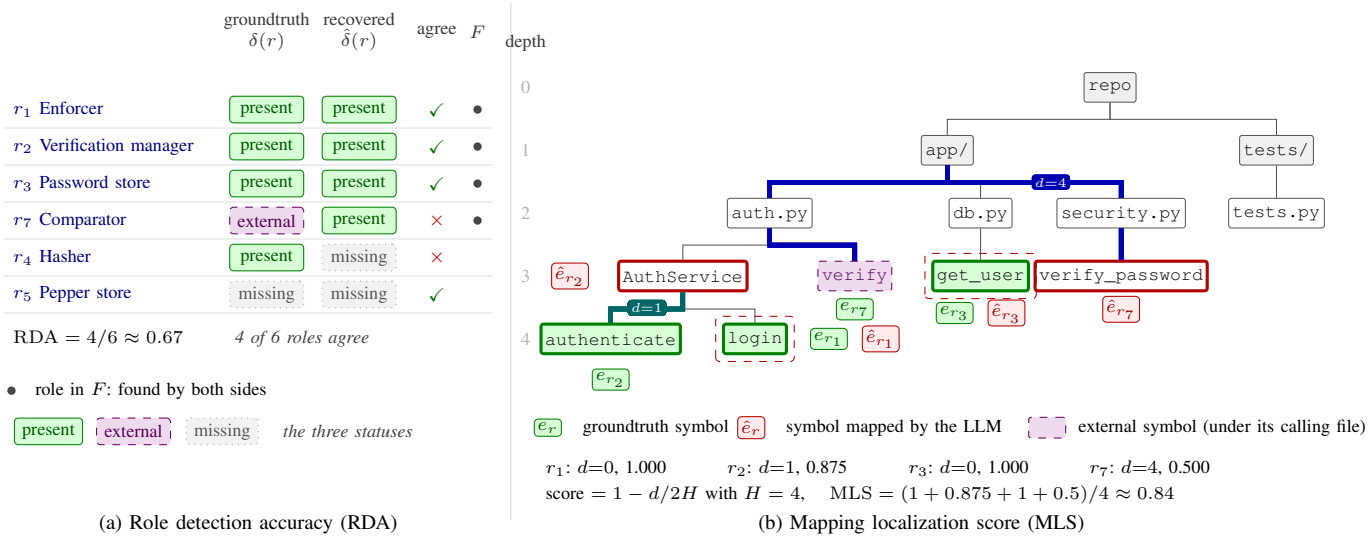
  status   "present" for in-repo code; "external" for a library,
           framework or service the repo only calls or configures; "missing"
           if not found.
  entity   The bare name as declared, with no enclosing class or module
           qualifier - "authenticate_user", or "hashpw" for a library symbol.
           Logic with no symbol of its own is cited by the innermost named
           entity containing it. Empty only for a role not found.
  file     Where the entity is declared; for a library symbol, where the repo
           imports or calls it. Empty if the role is missing.
  lines    The entity's single declaration line, e.g. "12". Empty if missing.

"interaction_order" lists the interactions in execution order, one entry each,
its "line" the call site's line number or 0 where that cannot be pinpointed.
It is [] if the order cannot be told."""
```

Fig. 15. The system prompt of the one-shot baseline.

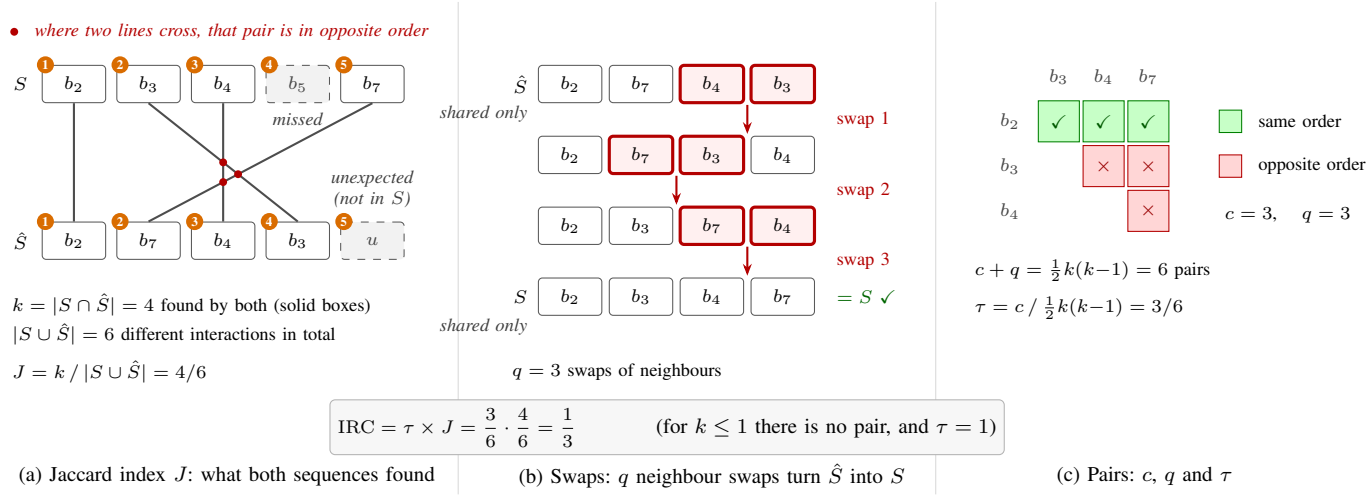
D. Computing the Metrics on an Example

Figures 16 and 17 show how RDA, MLS and IRC (Section IV-C) are computed on a small example.



(a) Role detection accuracy (RDA) (b) Mapping localization score (MLS)

Fig. 16. RDA and MLS on a small example. (a) RDA: 4 of the 6 roles have the same presence status in the groundtruth and in the recovery; the 4 roles in F are found by both. (b) MLS: for each role in F, the distance d in the containment tree between the groundtruth symbol e_r (green) and the mapped symbol $\hat{e}_r$ (red), scored $1 - d/2H$.



(a) Jaccard index J: what both sequences found (b) Swaps: q neighbour swaps turn $\hat{S}$ into S (c) Pairs: c, q and τ

Fig. 17. IRC on a small example, with interactions named by the actions b_j of Figure 1. $\hat{S}$ misses b_5 and has an unexpected interaction u. (a) $k = 4$ of the 6 interactions are shared, so $J = 4/6$. (b) Turning $\hat{S}$ into S takes $q = 3$ neighbour swaps. (c) Of the 6 pairs of shared interactions, $c = 3$ keep their order, so $\tau = 3/6$.

Appendix B
Recovery Output Format

Figure 18 shows the output of our pipeline for the login handler of Figure 2: the role mappings $\hat{M}$ and presence statuses $\hat{\mathcal{D}}$ that the LLM emits (Section III-B1), and the interaction sequence $\hat{S}$ that the CPG analysis derives from them (Section III-B2).

```
{ "role_mappings": [
    {"patternRole": "Enforcer",
     "status": "present", "entity": "login",
     "file": "app.py", "lines": "16"},
    {"patternRole": "Verification manager",
     "status": "present", "entity": "authenticate",
     "file": "app.py", "lines": "9"},
    {"patternRole": "Password store",
     "status": "present", "entity": "get_user",
     "file": "app.py", "lines": "6"},
    {"patternRole": "Comparator",
     "status": "external", "entity": "verify",
     "file": "app.py", "lines": "11"} ] }
```


(a) Role mappings $\hat{M}$ and presence statuses $\hat{\mathcal{D}}$


```
{ "interaction_order": {
    "backend": "joern",
    "entryRole": "Enforcer",
    "interactions": [
      {"rank": 1, "from": "Enforcer",
       "to": "Verification manager",
       "file": "app.py", "line": 17},
      {"rank": 2, "from": "Verification manager",
       "to": "Password store",
       "file": "app.py", "line": 10},
      {"rank": 3, "from": "Verification manager",
       "to": "Comparator",
       "file": "app.py", "line": 11} ] } }
```


(b) Interaction sequence $\hat{S}$

Fig. 18. The expected recovery output for the login handler of Figure 2, as JSON: (a) the role mappings $\hat{M}$ and presence statuses $\hat{\mathcal{D}}$ emitted by the LLM, and (b) the interaction sequence $\hat{S}$ derived from the CPG.

APPENDIX C
USING CODE PROPERTY GRAPHS FOR INTERACTION RECOVERY

To recover the interaction sequence $\hat{S}$, we traverse the code property graph (CPG) of the codebase C from the code symbol $\hat{e}$ that one role is mapped to, to the code symbols of the other roles, following the mappings $\hat{m} = (r, \hat{e}) \in \hat{M}$ (Section III-B2). We build the CPG with Joern, which implements the CPG of Yamaguchi et al. [24]. This appendix first explains why the CPG that Joern builds is not enough for this task on its own (Appendix C-A), and then how we added the missing links and defined our own traversal rules to move between the roles (Appendix C-B).

A. Challenges in Building a Repository-Level CPG

In Joern's CPG, every node is one piece of code, a method or a statement or expression inside it, with a type such as `METHOD` or `CALL` and properties such as `name` or `fullName`. Every edge also has a type, and our traversal follows the four kinds in Table IV. In the figures of this appendix, the code is on the left and the graph on the right, where each box is a node (its type in bold, its properties below) and each arrow an edge, labelled with its type.

The CPG is built per method. The control-flow edges, which give the order in which the code runs, never leave a method (Figure 19). The graph of a codebase is therefore a set of islands, one per method, and the only way from one island to another is a call edge. The code symbols $\hat{e}$ that the roles $r \in R$ are mapped to, however, are rarely in the same method, and often not in the same file, so recovering their interactions depends almost entirely on the call edges between methods across the codebase.

Call edges are often missing. Joern links a call to the method it runs through the address it infers for the call, `methodFullName`, with three possible outcomes (Figure 20): the call is linked to a method of the codebase, which we can traverse into; to a placeholder for a library method, which has no code; or to nothing at all. A call between two files of the same codebase often ends up in the second or third case, for example when the called function is re-exported by a Python package, or when Python gives no type for the object a method is called on. Joern also links a name to the variable it refers to (Figure 21), and a function passed as a value, such as a callback, to its method (Figure 22).

The way a security control is implemented can hide its calls. Whether a call between two roles appears in the graph also depends on the libraries and frameworks the developers built the security control with. In Spring, the framework passes a login request to the codebase's own provider inside library code, which is not in the graph, and builds the objects that roles call through `@Bean` methods; in FastAPI, a dependency declared as `Depends(f)` is called by the framework, and Joern's Python frontend drops it from the graph altogether. In all these cases, two roles that do interact when the code runs have no path between them in Joern's CPG, and a traversal of that graph alone misses their interaction. We therefore add the missing edges ourselves, as described next.

B. Traversing between Security Pattern Roles

1) Traversal rules: **Where the traversal starts.** The traversal starts at the code symbol $\hat{e}$ of the *entry role*: the role that sends the first action b_1 of the pattern $P = (R, B)$. If that role is not mapped to any code ($\hat{\delta}(r) = \text{MISSING}$), the sender of the next action b_2 is taken instead, and so on (Figure 23).

Placing the roles on the graph. Each mapping $\hat{m} = (r, \hat{e}) \in \hat{M}$ gives the code symbol $\hat{e}$ (a method, class, variable or field) that role r is mapped to, with its file and line. We look for a node declared under that name in that file, preferring one on the mapped line, and place r on it. A role mapped to a class also covers the class's methods, and a role mapped to a library function ($\hat{\delta}(r) = \text{EXTERNAL}$), which has no code in C, is placed on the calls that C makes to that function. One node may carry several roles.

How the traversal moves. The traversal follows the graph in the order the code would run: from one statement to the next, into a called method and back to the statement after the call, and through both branches of a condition, the first-written one first. It never visits the same method or statement twice, so loops and recursion end. Throughout, it acts as one role, starting with the entry role. When it reaches a node while acting as role r_i:

- if the node carries another role r_j, we record the interaction $r_i \to r_j$ and continue into the code of r_j, now acting as r_j;

```
def login(user):
    check(user)
    log(user)
```

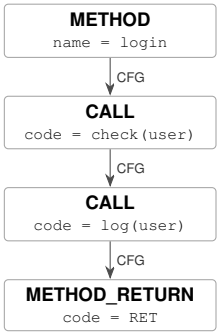


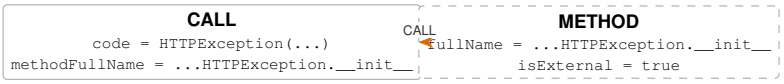
Fig. 19. `CFG` edges: the chain runs from the `METHOD` node, through each call in the order it runs, to the `METHOD_RETURN` node. The argument nodes, which come before each call, are left out.

Linked to a repository method

```
self.get_tenant_id(name)
```

Linked to a placeholder (library)

```
HTTPException(
    HTTP_401_UNAUTHORIZED)
```



No address, no edge

```
controller_function(
    tenant = ..., ...)
```

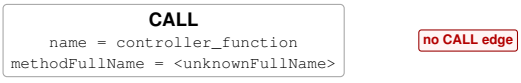


Fig. 20. The three outcomes of linking a call. Dashed orange arrows are `CALL` edges; the dashed box is a placeholder method, which has no code.

```
def show_tenant(self, name):
  return self.proxy_controller_function(
    tenant.get_tenant,
    id=self.get_tenant_id(name))
```

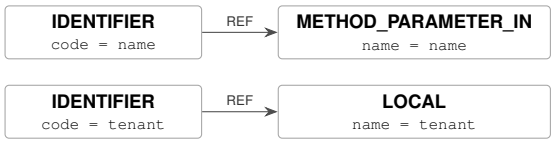


Fig. 21. `REF` edges: the name `name` refers to the method's parameter, and the name `tenant` to a local variable.

```
self.proxy_controller_function(
    tenant.get_tenant, ...)
```

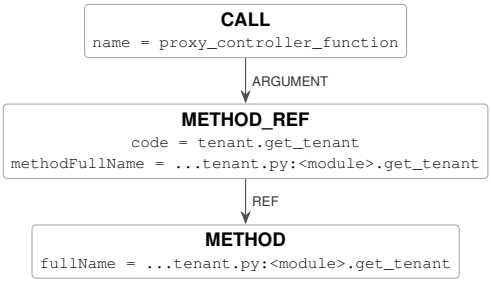


Fig. 22. A method reference: the function `tenant.get_tenant`, passed as an argument, is a `METHOD_REF` node with a `REF` edge to its `METHOD`.

TABLE IV

THE EDGES OF JOERN'S GRAPH THAT OUR TRAVERSAL FOLLOWS. *Joern step* IS THE NAME OF THE TRAVERSAL IN JOERN'S QUERY LANGUAGE; *Label* IS WHAT OUR TRAVERSAL RECORDS ON AN INTERACTION REACHED THROUGH THE EDGE.

Edge	Joern step	Connects	Label
Control flow	`cfgFirst`, `_cfgOut`	a node to the node of the same method that runs next	—
Call	`call.callee`	a call to the method it runs	`call`
Reference	`identifier._refOut`	a name to the variable, parameter or field it refers to	`data`
Method reference	`methodRef.referencedMethod`	a function passed as a value (a callback, a lambda, a nested function) to its method	`route-registration` if passed to a call, else `nested-definition`

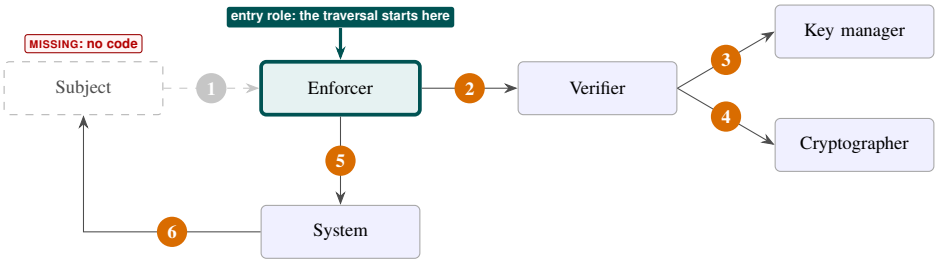


Fig. 23. Choosing the entry role from the actions B of the *Verifiable token-based authentication* pattern. Boxes are the pattern's roles $r \in R$ and numbered arrows its actions $b_1, \ldots, b_6$, in order. The sender of b_1, the Subject, is MISSING (dashed), so b_1 is skipped (grey) and the sender of b_2, the Enforcer, becomes the entry role.

- if the node is a method with no role, such as a helper, we record nothing and continue into it, still acting as r_i, since roles are often linked only through such helpers;
- if the node carries the same role r_i, we record nothing and do not go in.

A node with several roles gives one interaction for each, in the order of the actions B. The recorded interactions, in order and without repeats, form $\hat{S}$. Since both branches are followed, $r_i \to r_j$ is recorded whenever some path leads from the code of r_i to that of r_j, and a role that cannot be reached from the entry role is left out of $\hat{S}$. Figure 24 outlines these rules, and Figure 25 shows the order in which the traversal visits the statements of a small example.

2) Edges we add: Where Joern's graph lacks a link between two roles that interact, we add an edge of our own (Table V). At a call, we always try Joern's edge first and use ours only when Joern's leads to no code of the codebase. We never add an edge by searching the codebase for a method with a matching name: an earlier version of our traversal did so, and on one codebase it recovered six interactions, five of them wrong, because one wrong link sends the traversal into unrelated code and every interaction found there is credited to the wrong role. Each case below comes with a short example: the code on the left, (a) Joern's graph, where a red dashed arrow marks the missing link, and (b) the same graph with the edge we add (solid teal), where the shaded boxes are what we read to build it.

a) Import binding: Joern sometimes gives a call to an imported function the wrong address. In Python, `from auth import verify` is read as the file `auth.py`; when `auth` is a package that re-exports `verify` from `auth/core.py`, no method has that address, and the call is linked to a placeholder, as if it were a library call (Figure 26a). Java statically imported methods have the same problem. The import statement of the calling file names the right method, so we follow it, through the re-export, to the file that defines it, and link the call there (Figure 26b).

b) Receiver class (Python): To link a call `x.m()`, Joern needs the type of `x`, which Python does not declare: `self.tokens.verify(token)` gets no address and no call edge, although `TokenVerifier.verify` is in the codebase (Figure 27a). We look at what the code assigns to the object, here `self.tokens = TokenVerifier()` in `__init__`, and link the call to `verify` on that class (Figure 27b). This is the edge used at step 7 of Figure 25b.

c) Field access: Joern stores a read such as `this.key` as a field-access call on the object and the field's name, without an edge to the field itself (Figure 28a), so a role mapped to the field is never reached from the code that reads it. We take the object's class, find the field with that name in it or in its parent classes, and link the read to it (Figure 28b).

d) Override dispatch (Java): Spring code often calls a method on a library interface, such as `authManager.authenticate(auth)`, while at run time Spring supplies a class of the codebase that implements it. The interface's code is not in the graph, so the call is linked to a placeholder (Figure 29a). We find the classes of the codebase that implement the interface, directly or through a parent, and link the call to their method with the same name and number of parameters (Figure 29b). We take at most one such step along a chain of helper calls, so that one guess is never built on another.

```
walk(m, start, ctx, via):                    -- ctx: the roles the walk acts as
  if (m, start, ctx) was walked before: return
  if start is m's first statement:
    for t in edges added at the start of m: reach(t, ctx, via)
  stack <- [start];  seen <- {}
  while stack is not empty:
    n <- stack.pop()
    if n in seen: continue
    seen.add(n)
    for t in edges(n): reach(t, ctx, via)          -- Joern's edges and added ones
    push the control-flow successors of n in reverse order

reach(t, ctx, via):
  pairs <- { (a, b) : a in ctx, b in roles(t), a != b }
  if pairs is not empty:
    record each pair, ordered by the pattern's actions B
    if t has a body: walk(t, first(t), targets of pairs, [])  -- act as the new role
  else if roles(t) is empty and t has a body:
    walk(t, first(t), ctx, via + [t])                        -- helper: same role
```

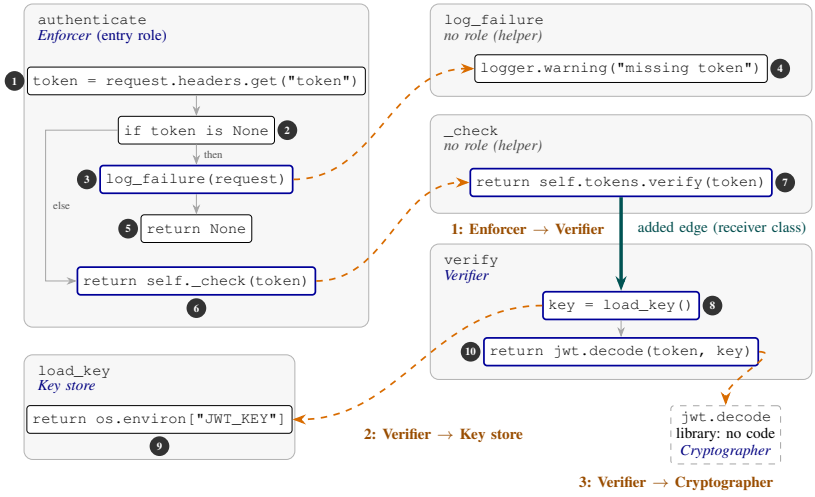
Fig. 24. Our traversal in outline. `walk` steps one method; `reach` decides what reaching a node means.

```
# app/middleware.py
 1| class AuthMiddleware:
 2|     def __init__(self):
 3|         self.tokens = TokenVerifier()
 4|
 5|     def authenticate(self, request):
 6|         token = request.headers.get("token")
 7|         if token is None:
 8|             log_failure(request)
 9|             return None
10|         return self._check(token)
11|
12|     def _check(self, token):
13|         return self.tokens.verify(token)
14|
15| def log_failure(request):
16|     logger.warning("missing token")
```

```
# app/tokens.py
1| class TokenVerifier:
2|     def verify(self, token):
3|         key = load_key()
4|         return jwt.decode(token, key)
5|
6| def load_key():
7|     return os.environ["JWT_KEY"]
```

Role r	Symbol $\hat{e}$	Mapped at
Enforcer	`authenticate`	`middleware.py:5`
Verifier	`verify`	`tokens.py:2`
Key store	`load_key`	`tokens.py:6`
Cryptographer	`decode` (library)	`tokens.py:4`

(a) The code (illustrative; imports omitted) and its role mapping.



(b) The graph the traversal sees.

Fig. 25. The worked example. In (b), each box is one method. Grey arrows are control-flow edges; dashed orange arrows are call edges from Joern; the thick teal arrow is an edge we add. The dashed box is Joern's placeholder for a library function, which has no code. Black circles give the order in which the traversal visits the statements, and the three interactions it records are numbered on the edges that produce them.

e) Framework route (Java): Some hand-offs happen entirely inside library code. A Spring Security login filter calls `getAuthenticationManager().authenticate(req)` and Spring's `ProviderManager` then passes the request to the codebase's own `AuthenticationProvider`. The codebase does not implement the interface that the call names, so even override dispatch finds nothing (Figure 30a). We write this hand-off once, as a rule for Java: a call to `AuthenticationManager.authenticate` runs `AuthenticationProvider.authenticate`. We apply it only when nothing else links the call, and link the call to the codebase's implementation (Figure 30b).

f) Injection provider (Java): A call such as `passwordEncoder.matches(raw, hash)` runs a library object that Spring built by calling a method of the codebase marked `@Bean`. Joern links the call to a placeholder (Figure 31a), so a role mapped to that method, such as the Hasher, is never reached. We find the `@Bean` methods whose

app.py

```
from auth import verify
verify(token)
```

auth/__init__.py

```
from .core import verify
```

auth/core.py

```
def verify(token): ...
```

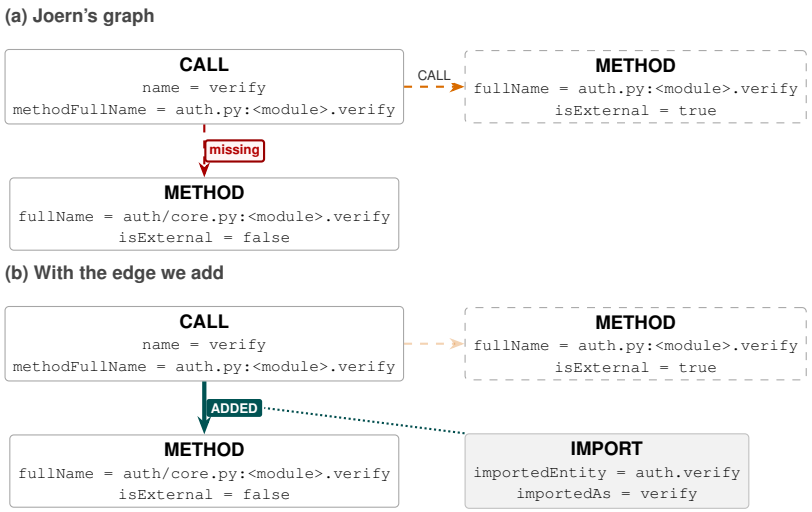


Fig. 26. Import binding: Joern's graph (a) and the edge we add (b).

```
def __init__(self):
    self.tokens = TokenVerifier()

def check(self, token):
    self.tokens.verify(token)
```

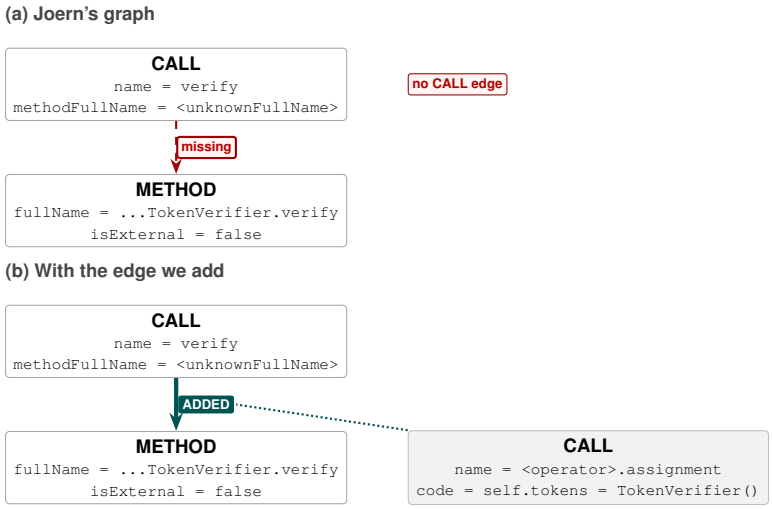


Fig. 27. Receiver class: Joern's graph (a) and the edge we add (b).

```
class Signer {
  private Key key;
  byte[] sign(byte[] m) {
    return mac(this.key, m);
  }
}
```

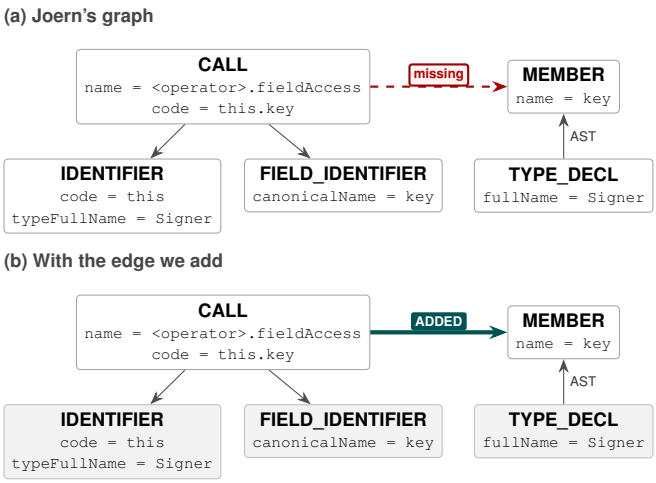


Fig. 28. Field access: Joern's graph (a) and the edge we add (b). Unlabelled grey arrows are ARGUMENT edges.

```
authManager.authenticate(auth);

class UaaManager implements
    AuthenticationManager {
  Authentication authenticate(...)
  { ... }
}
```

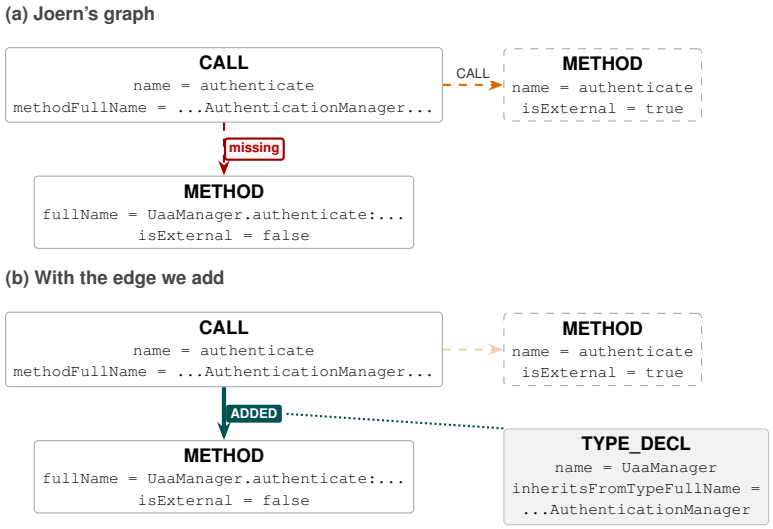


Fig. 29. Override dispatch: Joern's graph (a) and the edge we add (b).

```
// login filter
getAuthenticationManager()
    .authenticate(req);

class StandardProvider implements
    AuthenticationProvider {
  Authentication authenticate(...)
  { ... }
}
```

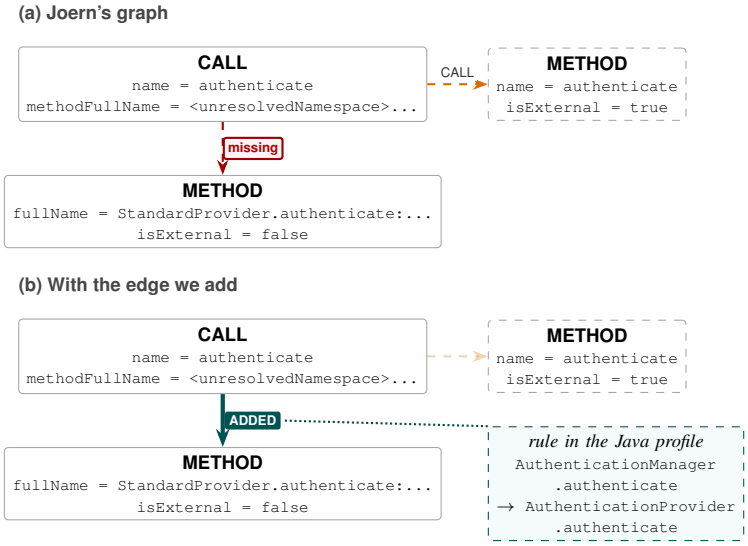


Fig. 30. Framework route: Joern's graph (a) and the edge we add (b). The dashed teal box is a rule in the Java profile, not a node of Joern's graph.

TABLE V
EDGES WE ADD TO JOERN'S GRAPH. *Label* IS RECORDED ON EVERY INTERACTION THE EDGE PRODUCES, SO INTERACTIONS THAT REST ON AN ADDED EDGE CAN BE TOLD APART FROM ORDINARY CALLS.

Added edge	Leads to	Built from	Label
Import binding	the repository method that the calling file's import names	Joern's import nodes	`call`
Receiver class (Python)	the method on the class the code assigns to the object a call is made on	Joern's assignment nodes	`call`
Field access	the field that a read or write refers to	Joern's field-access node and the object's class	`data`
Override dispatch (Java)	the repository's implementations of a library interface method	Joern's class hierarchy, method names and parameter counts	`dispatch`
Framework route (Java)	the repository code that Spring Security passes a login request to	a rule written for that framework	`dispatch`
Injection provider (Java)	the `@Bean` method that builds the object a call is made on	Joern's annotation nodes and return types	`dependency-injection`
Parameter default (Python)	the functions named in `Depends(f)` parameter defaults	the method's signature in the source text	`dependency-injection`

return type is the type of the object the call is made on, and record their role at the call (Figure 31b). We do not enter the method, which runs when the application starts, not during the request.

g) Parameter default (Python): In FastAPI, a parameter written as `user = Depends(get_user)` makes the framework call `get_user` before the function body runs. Joern's Python frontend drops parameter default values, so nothing in the graph links `read_me` to `get_user` (Figure 32a). We read the signature from the source file and link `read_me` to `get_user` before its first statement (Figure 32b).

3) Lessons learned: **Choosing among several methods.** Some calls lead to several possible methods: a Java interface call has one Joern edge per implementing class, and override dispatch may find several implementations. Only one of them runs, and the graph does not say which, so we try each one separately and keep the one that reaches the most roles.

One traversal, one rule set per language. The traversal is the same for every language. What differs between Python and Java, such as how an import is mapped to a file, which framework rules apply and how parameter defaults are read, is kept in a small rule set per language. A language without a rule set is not analysed.

Assumptions behind the added edges. Override dispatch and framework routes assume that the framework behaves as documented, for instance that Spring passes the login request to the codebase's provider; the codebase's configuration is not checked. Each added edge labels the interactions it produces (Table V), so those that rest on such an assumption can be set apart.

```
// class SecurityConfig
@Bean
PasswordEncoder encoder() {
  return new BCrypt...();
}

passwordEncoder.matches(
    raw, hash);
```

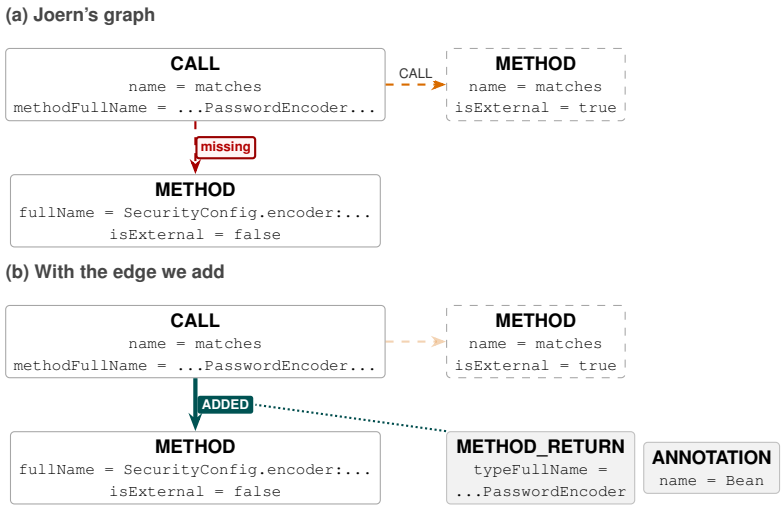


Fig. 31. Injection provider: Joern's graph (a) and the edge we add (b).

```
1 def read_me(
2     user = Depends(get_user)):
3     return user.name
4
5 def get_user(): ...
```

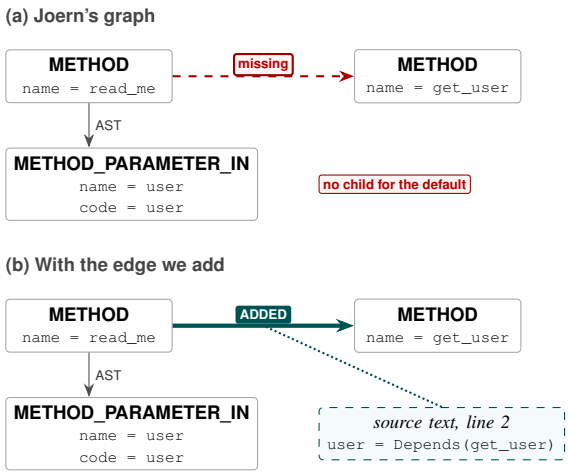


Fig. 32. Parameter default: Joern's graph (a) and the edge we add (b). The dashed teal box is read from the source file, not from Joern's graph.

APPENDIX D
GROUNDTRUTH ANNOTATION

A. Generating Candidate Mappings with Claude Code

Chat transcript from Claude Code. We publish the chat transcript that produced the preminilary mappings for the 100 recovery instances of our evaluation among 5 patterns. It is included in our customized Huggingface bucket for this paper, and can be downloaded from https://huggingface.co/buckets/AnonymousSpottedToad/securityPatternsRecovery.

B. Annotation Interface

Figure 33 shows the part of our annotation interface that annotators use to verify the interaction sequence, here for P2 Verifiable-token authentication in `freqtrade`. The *Interaction order* panel lists the candidate interactions that the CPG traversal derives from the current mappings, each with the file and line of its call, together with the roles that are left out of the order and why. Whenever annotators change a mapping, they can re-detect the order and save it once it reflects the pattern. The *Interaction graph* panel shows every call between the mapped roles with its code, so that annotators can check each interaction against the source code before approving it.

C. Annotation Process

Of the 500 roles in our 100 groundtruth records (Section D-D), annotators changed 114 (22.8%) from the candidate roles recovered by Claude Code and kept the other 386 (77.2%) unchanged. The two annotators first annotated 114 roles independently, with an inter-annotator agreement of 0.17 (Cohen's κ). They then resolved their disagreements on these roles together, and annotated the rest of the roles together.

D. Dataset Statistics

Figure 34 shows the size of the 93 codebases, in tokens and in KLOC. Tables VI and VII give the roles by presence status and the interactions of our groundtruth, per pattern, for Java and Python.

TABLE VI
GROUNDTRUTH PER PATTERN FOR JAVA (10 CODEBASES EACH): ROLES BY PRESENCE STATUS, AND INTERACTIONS.

		#Roles			
Pattern	#Repos	Present	External	Missing	#Interactions
P1 Password-based authentication	10	33	14	23	39
P2 Verifiable-token authentication	10	28	12	0	27
P3 Obscure-token access control	10	30	6	4	28
P4 Session-based access control	10	31	11	18	25
P5 Rate limiting	10	34	6	0	34
Total	50	156	49	45	153

TABLE VII
GROUNDTRUTH PER PATTERN FOR PYTHON (10 CODEBASES EACH): ROLES BY PRESENCE STATUS, AND INTERACTIONS.

		#Roles			
Pattern	#Repos	Present	External	Missing	#Interactions
P1 Password-based authentication	10	32	17	21	31
P2 Verifiable-token authentication	10	31	9	0	24
P3 Obscure-token access control	10	33	0	7	19
P4 Session-based access control	10	42	0	18	19
P5 Rate limiting	10	40	0	0	34
Total	50	178	26	46	127

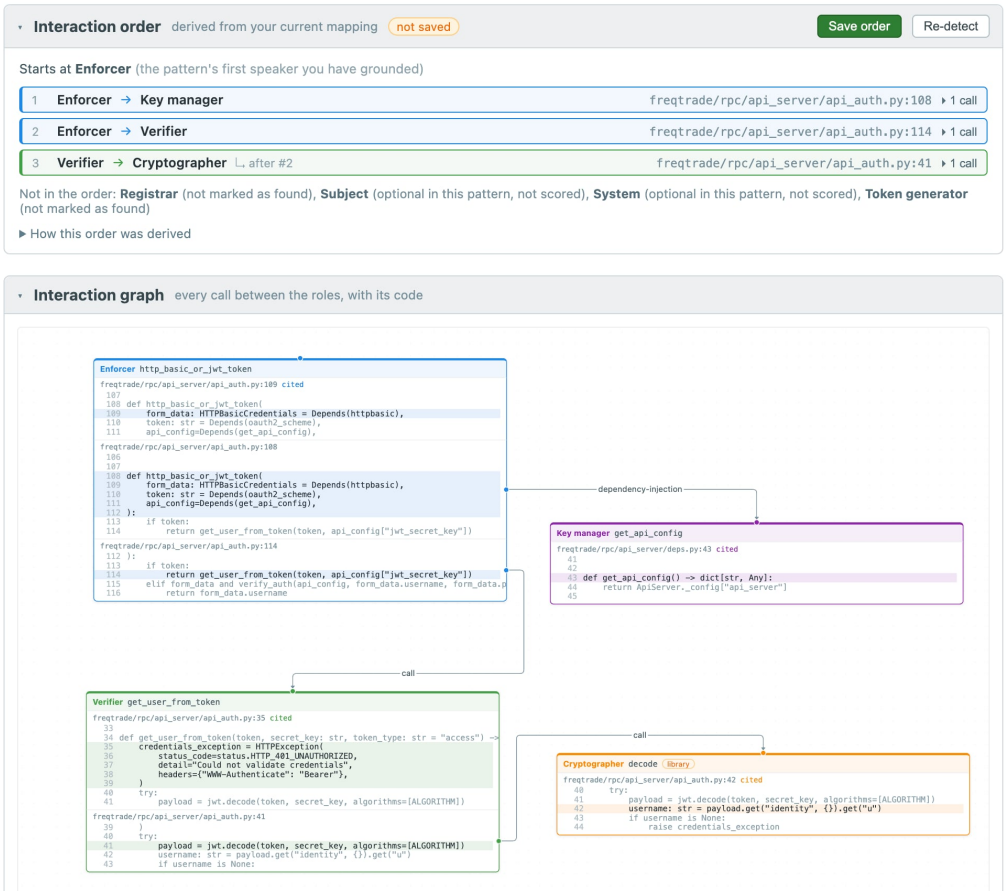


Fig. 33. Annotation interface for P2 Verifiable-token authentication in `freqtrade`. Top: the interaction order derived from the current mappings. Bottom: every call between the mapped roles, with its code.

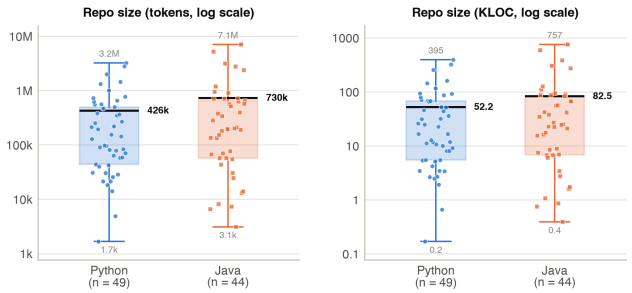


Fig. 34. Size of the 93 codebases (49 Python, 44 Java) in `o200k_base` tokens and in KLOC.

TABLE VIII
INSTANCES WITH THE HIGHEST MLS (TIES COUNT FOR EACH LLM) AND WITH MLS = 1, OUT OF 100.

LLM	Highest MLS	MLS = 1
GPT-6.1	**54**	**27**
DeepSeek	44	20
GLM	37	17
Muse-Spark	43	16

APPENDIX E
ADDITIONAL RESULTS

This appendix gives the figures and the table that Section V refers to: the mean RDA, MLS and IRC of our pipeline per LLM and language (Figure 35, RQ1) and the instances with the highest MLS (Table VIII, RQ1); the tokens and cost per run of our pipeline (Figure 36, RQ2); for RQ3, RDA, MLS and IRC per pattern against the one-shot baseline (Figure 37), the mean RDA, MLS and IRC against the baseline with and without the instances over its input limit (Table IX), the tokens and cost per run of the baseline (Figure 38) how the cost per run grows with codebase size (Figure 39) and IRC by MLS band (Figure 40); and the change when one search tool is removed (Table X, RQ4).

APPENDIX F
FAILURE CASES

This appendix shows instances where the CPG analysis cannot recover interactions of the groundtruth although the LLM detected the roles correctly.

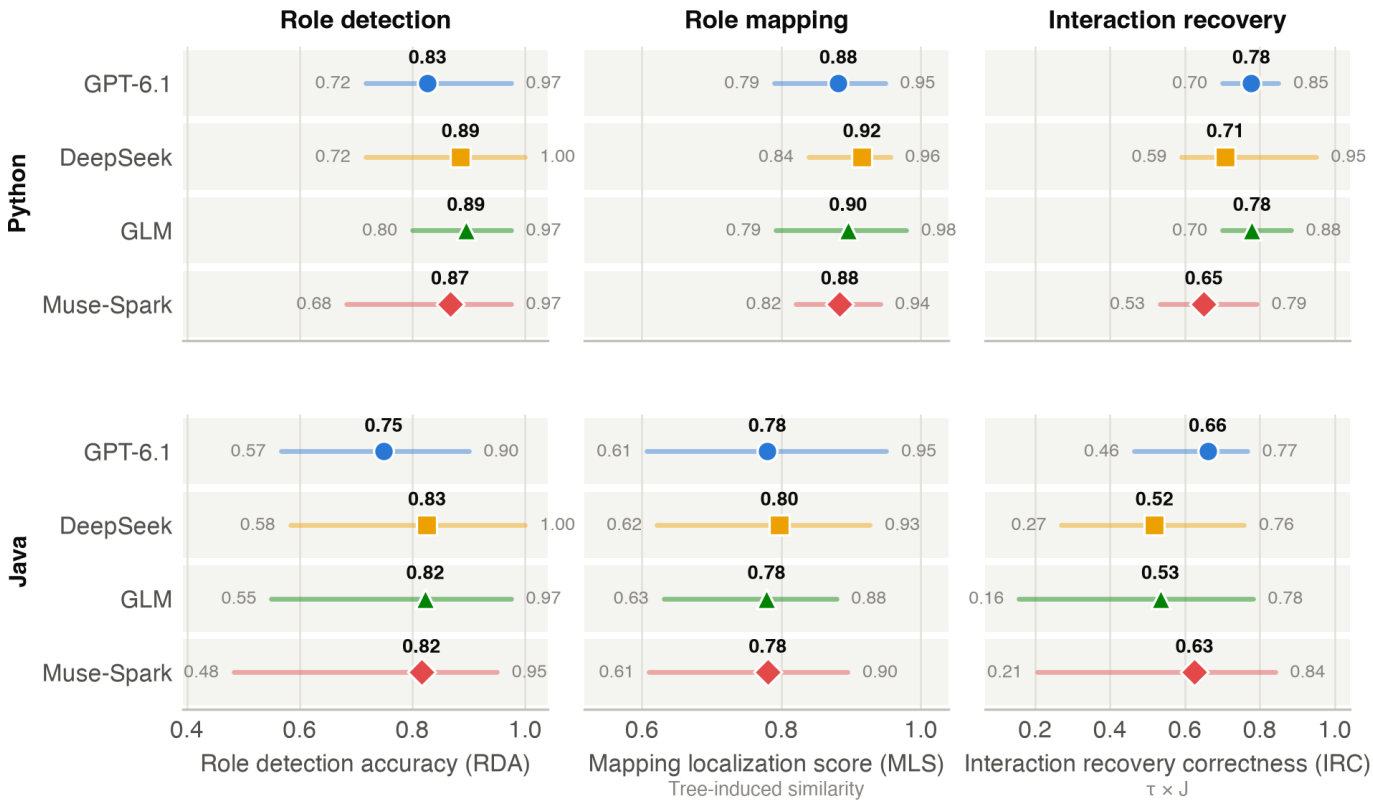


Fig. 35. Mean RDA, MLS and IRC of our pipeline per LLM and language. Bold: mean over the 50 instances; whiskers: lowest and highest pattern mean.

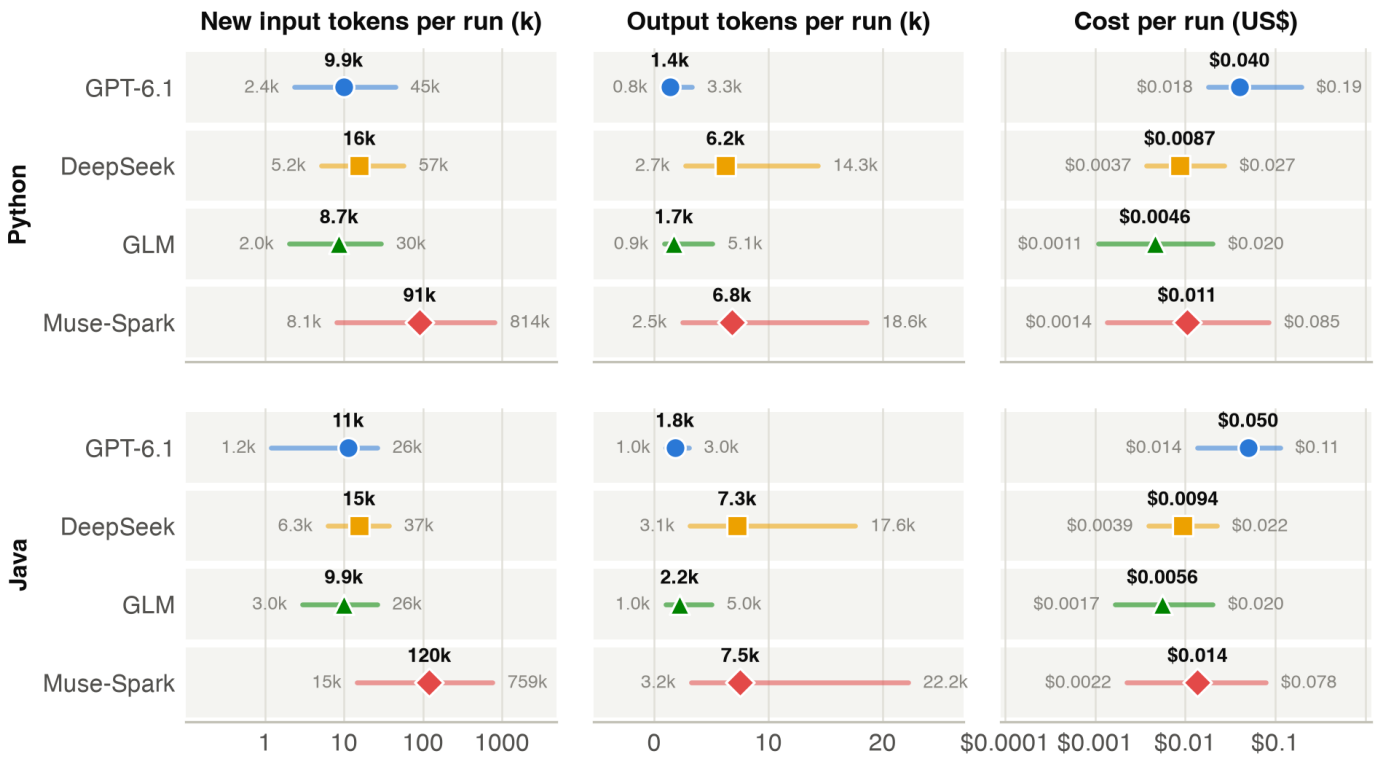
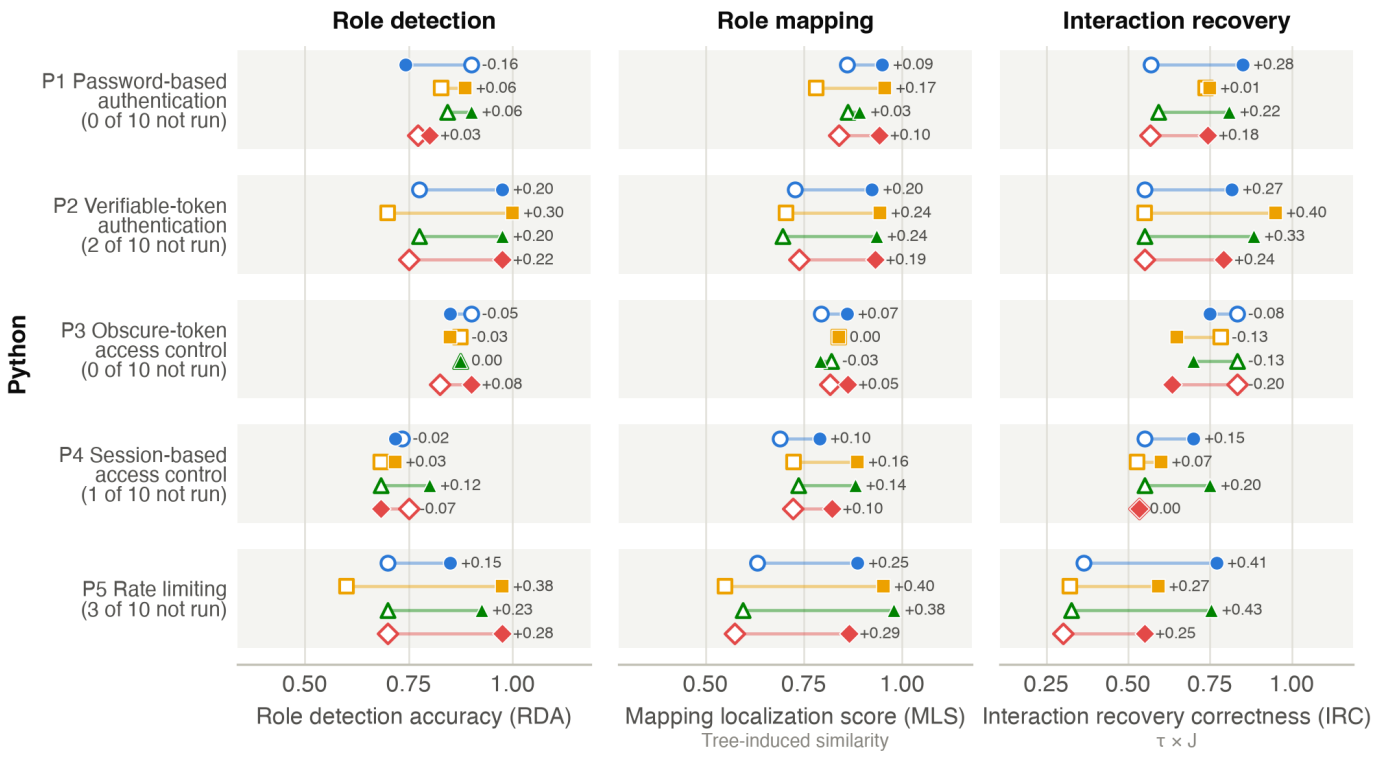
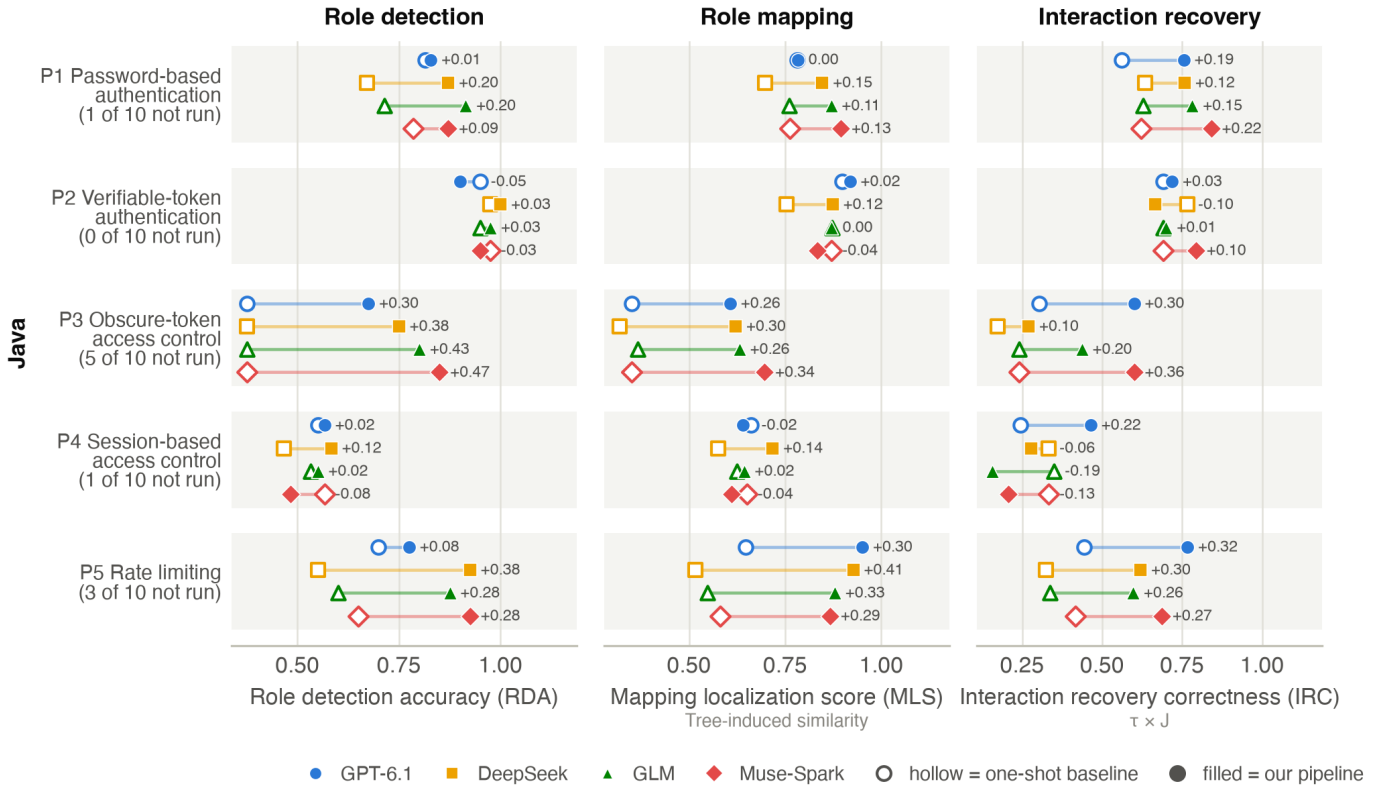


Fig. 36. Tokens and cost per run of our pipeline, per LLM and language. Bold: mean over the 50 runs; line: lowest to highest run. New input excludes prompt-cache hits; cost uses public API prices, also for the self-hosted DeepSeek and GLM.



(a) Python



(b) Java

Fig. 37. Mean RDA, MLS and IRC per pattern for (a) Python and (b) Java: one-shot baseline (hollow) against our pipeline (filled), with the difference beside each pair. Instances over the baseline's 900K-token input limit score 0 for the baseline; their number is under each pattern.

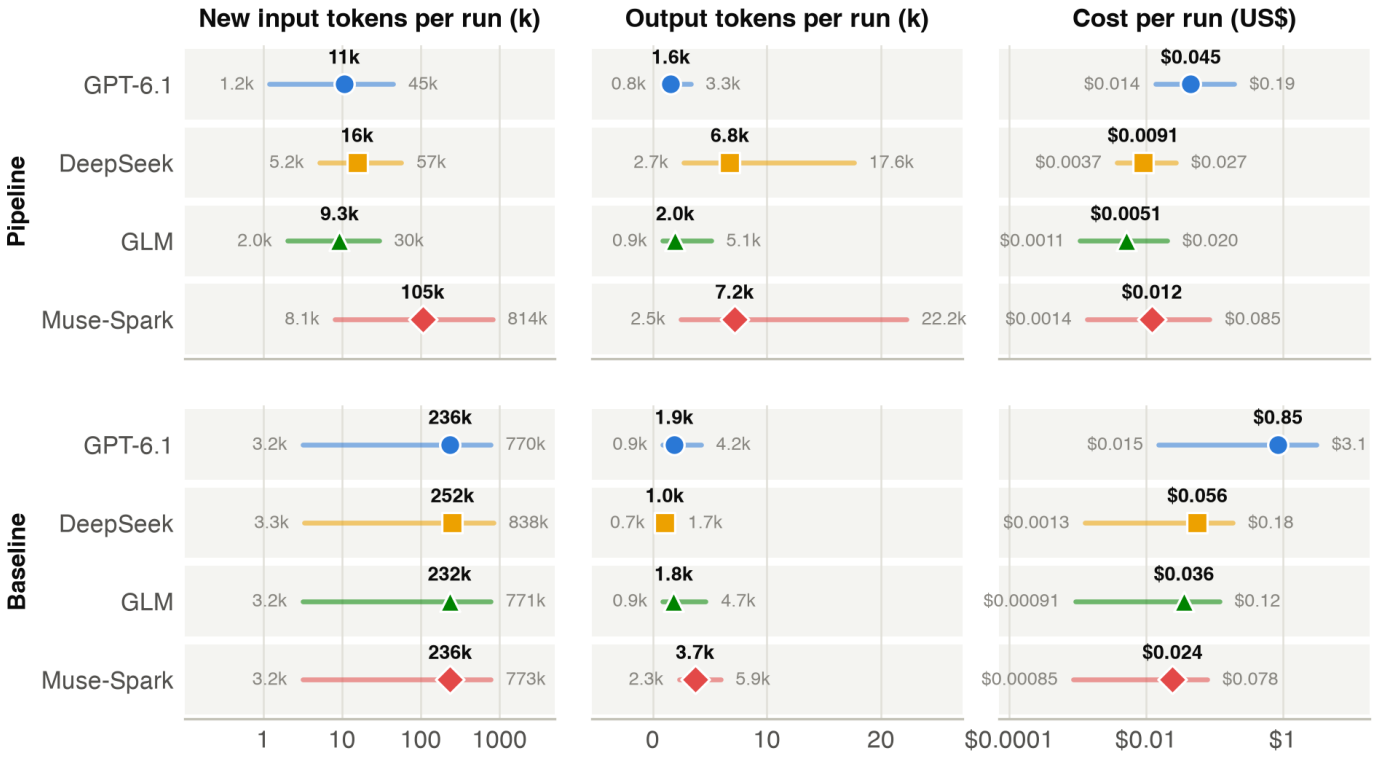


Fig. 38. Tokens and cost per run of our pipeline (top) and the one-shot baseline (bottom), both languages, drawn as in Figure 36. The baseline covers the 84 instances under its 900K-token input limit.

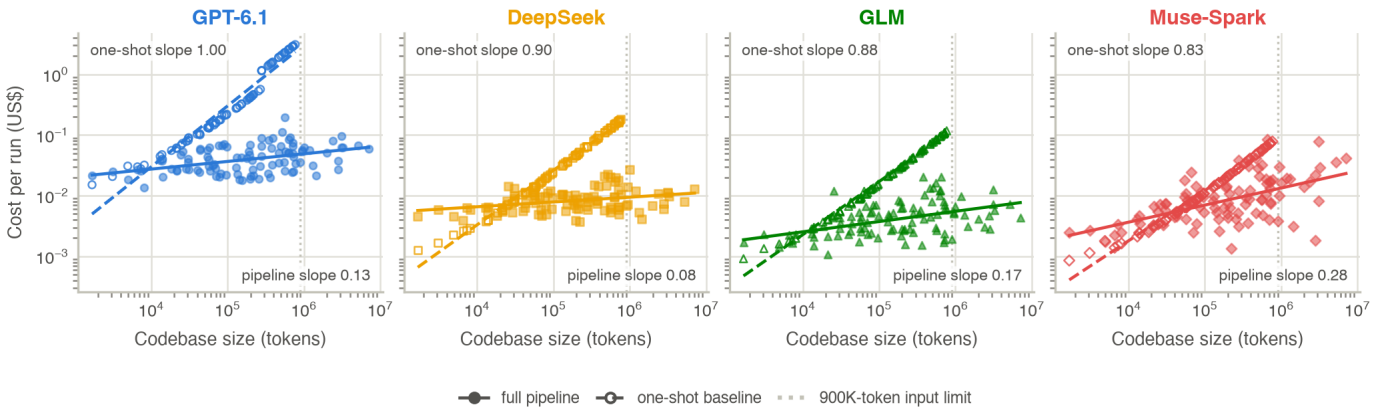


Fig. 39. Cost per run against codebase size, log-log: our pipeline (filled, solid fit) against the one-shot baseline (hollow, dashed fit). A slope of 1 means the cost grows in proportion to the size. Dotted: the baseline's 900K-token input limit.

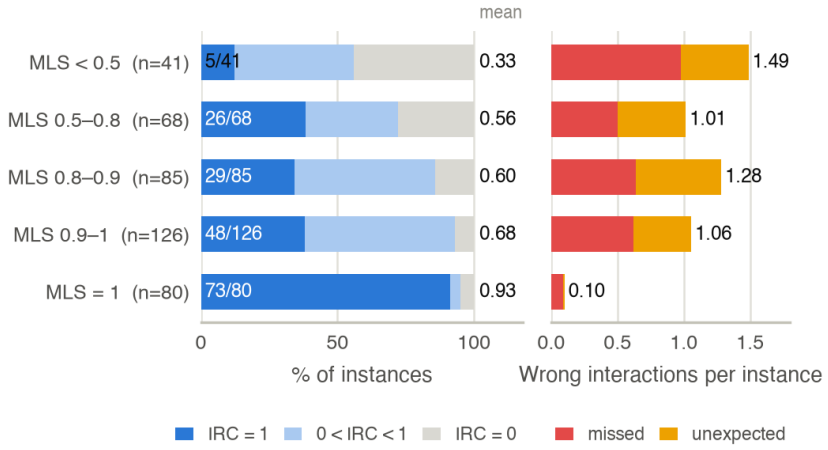


Fig. 40. IRC of our pipeline by MLS band, over 400 instances (4 LLMs × 100). Left: share of instances with a perfect, partial or zero IRC (the number of perfect ones in the bar) and the band's mean IRC. Right: missed and unexpected interactions per instance.

TABLE IX
MEAN RDA, MLS AND IRC OF THE ONE-SHOT BASELINE (BASE) AND OUR PIPELINE (OURS) PER LLM, OVER ALL 100 INSTANCES (THE 16 OVER THE BASELINE'S INPUT LIMIT SCORE 0 FOR THE BASELINE) AND OVER THE 84 INSTANCES BOTH CAN RUN. BOLD: THE HIGHER OF THE TWO.

	RDA		MLS		IRC	
LLM	Base	Ours	Base	Ours	Base	Ours
All 100 instances						
GPT-6.1	0.74	**0.79**	0.70	**0.83**	0.51	**0.72**
DeepSeek	0.67	**0.86**	0.65	**0.86**	0.51	**0.61**
GLM	0.70	**0.86**	0.69	**0.84**	0.51	**0.66**
Muse-Spark	0.71	**0.84**	0.69	**0.83**	0.51	**0.64**
84 instances under the input limit						
GPT-6.1	**0.88**	0.78	**0.84**	0.83	0.61	**0.73**
DeepSeek	0.80	**0.86**	0.77	**0.87**	0.61	**0.64**
GLM	0.84	**0.85**	0.82	**0.84**	0.61	**0.68**
Muse-Spark	**0.85**	0.83	0.82	**0.84**	0.61	**0.65**

A. Unconnected Enforcers in Session-Based Access Control

Figure 41 shows why P4 Session-based access control scores a low IRC in Java, on the codebase `ncats/gsrs-spring-starter`. The Authentication enforcer is the servlet filter's `doFilterInternal`. It checks the session and then hands the request to Spring with `filterChain.doFilter`. The Authorisation enforcer is the `@PreAuthorize` annotation that `UserController` carries through `@canManageUsers`. Spring connects the two at run time, in framework code, and the annotation's call to the Decider exists only inside a string. No call in the codebase links the two enforcers, so the CPG traversal from the Authentication enforcer (Section III-B2) never reaches the authorisation roles. On this instance, GPT-6.1 detects all six roles correctly (RDA $= 1$) but scores IRC $= 0$: its sequence shares only two authentication interactions with the groundtruth, in the opposite order. DeepSeek and GLM score IRC $= 0$ on this instance for the same reason.

TABLE X
CHANGE FROM OUR PIPELINE WHEN ONE SEARCH TOOL IS REMOVED: RDA, MLS AND IRC OVER BOTH LANGUAGES; NEW INPUT AND OUTPUT TOKENS (%), STEPS AND MEMORY (MB) PER RUN AND LANGUAGE. WITHOUT SEMANTIC SEARCH, NEITHER THE VECTOR DB NOR THE EMBEDDING MODEL IS LOADED.

	Accuracy			New input (%)		Output (%)		Steps		Memory (MB)	
LLM	ΔRDA	ΔMLS	ΔIRC	Py	Java	Py	Java	Py	Java	Py	Java
No keyword search											
GPT-6.1	-0.009	-0.015	-0.001	0	-2	-8	-6	-0.6	-0.5	0	0
DeepSeek	-0.002	-0.002	+0.088	+16	+11	-11	+4	-0.6	+0.8	0	0
GLM	+0.008	+0.001	-0.032	+40	+12	-6	-3	-0.7	-0.5	0	0
Muse-Spark	+0.023	+0.009	+0.032	-33	-30	-7	-5	-0.4	-1.0	0	0
No semantic search											
GPT-6.1	-0.009	+0.007	-0.016	-1	-3	0	-3	+0.5	-0.1	-165	-188
DeepSeek	-0.024	-0.027	+0.037	-3	+5	-9	+9	-1.0	+0.7	-165	-188
GLM	+0.019	+0.003	-0.038	+4	+8	+2	+7	+0.2	+2.1	-165	-188
Muse-Spark	+0.023	+0.006	+0.029	-41	-29	+2	+8	+0.1	+0.7	-165	-188

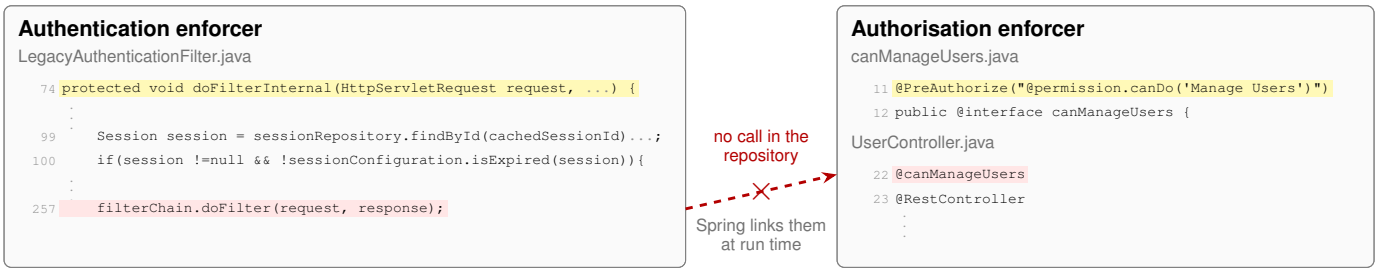


Fig. 41. The two enforcers of session-based access control in `ncats/gsrs-spring-starter`. The Authentication enforcer (left) ends by passing the request to Spring (line 257). Spring then applies the Authorisation enforcer (right) to `UserController`. No call in the repository joins the two, so the code property graph has no edge between them. Yellow marks each enforcer's entity, and red marks the two ends of the missing link.

APPENDIX G
ARTIFACTS

We release the dataset and the code of this paper as five anonymized artifacts (Table XI). This appendix maps each of them to the parts of the paper it supports, gives the names under which the paper's terms appear in them, and shows how the numbers we report are recomputed from them.

A. Names Used in the Artifacts

The code and the dataset name some of the paper's terms differently:

- *Metrics*: RDA, MLS and IRC are Level 1, Level 2 and Level 3, and 1 − score is reported as *drift*.
- *Patterns*: P1 is `authentication_pwd`, P2 `verifiable_token_based_authentication`, P3 `obscure_token_based_access_control`, P4 `session_based_access_control` and P5 `limit_request_rate`.
- *LLMs*: GPT-6.1 is `gpt-6.1-sol`, Muse Spark `muse-spark-1.3-contributor`, DeepSeek `deepseek-v4-flash-0731` and GLM `glm-5.3-flash`.
- *Search methods*: lexical (keyword) search is the agent's `grep` tool and semantic search its `search` tool, so the two settings of RQ4 are `ablation_no_grep` and `ablation_no_search`. The full pipeline is `pipeline` and the one-shot baseline `baseline`.

B. From the Dataset to the Reported Numbers

Groundtruth. Each file under `ground_truth/` keeps every role the annotators recorded, 758 rows in total, including Subject and System and some roles of the lifecycle flows, such as the Registrar of P1. The 500 roles of Table III are the roles marked as required in the pattern's `04_pattern.json`, and a required role without a row is counted as missing, which is the case for the Pepper store in three P1 records. Counted this way, the files give the 334 present, 75 external and 91 missing roles and the 280 interactions of Table III, cell by cell.

Scores. Under `experiment_outputs/`, one `evaluation.json` per experiment, LLM and language holds the RDA, MLS and IRC of its 50 instances. Averaging them gives the scores of Section V; for the full pipeline, the means over the four LLMs are an RDA of 0.84, an MLS of 0.84 and an IRC of 0.66. The `secpat evaluate` command of the SECPATREC repository recomputes these scores from the stored recoveries and the groundtruth, without calling any LLM. For the pipeline and the ablations, IRC derives the recovered interaction sequence $\hat{S}$ from the role mapping on the same CPG and with the same traversal as the groundtruth; for the baseline, it scores the sequence that the LLM states in its answer.

TABLE XI
THE ARTIFACTS OF THIS PAPER AND THE PARTS OF THE PAPER EACH ONE SUPPORTS.

Artifact	Link	Contents	Used in
Dataset	https://huggingface.co/buckets/AnonymousSpottedToad/securityPatternsRecovery	The 100 groundtruth architectures; the 93 codebases and their CPGs; the outputs of every experiment; the five specifications P; the Claude Code session that drafted the candidate mappings	Sections IV-B and V; Appendices A-A and D
SECPATREC	https://github.com/anonymousspottedtoad/secpatrec	The role detection and mapping agent, the one-shot baseline, the two ablations and the `secpat` command that runs them	Sections III-B and V
Interaction recovery	https://github.com/anonymousspottedtoad/secpat_interaction_recovery	The traversal of the Joern CPG: `walk.sc`, with the rules per language in `java.sc` and `python.sc`	Section III-B2; Appendix C
Evaluation metrics	https://github.com/anonymousspottedtoad/secpat_evaluation_metrics	RDA, MLS and IRC	Section IV-C; Appendix A-D
Annotation interface	https://github.com/anonymousspottedtoad/secpat_annotation_portal	The web interface the annotators used to verify the candidate architectures	Appendix D-B

Baseline input limit. The one-shot baseline is called only when the packed codebase fits in 900K tokens of the `o200k_base` tokenizer, below the 1M-token limit of Section IV-D. The 16 codebases above it have no recovery in the dataset and score 0 (Section V-C).